PERKFORGE / OPEN STUDY RESOURCE

DoD RMF & Security Assessment Field Guide

First Edition • October 2026

A practical reference for cybersecurity engineers, ISSOs, and aspiring Security Control Assessors.

10 study volumes • Visual quick references • 30-day learning plan • Kubernetes compliance mapping

Independent educational publication | US Letter printable format

About this edition

This collection brings together ten PerkForge study volumes, a master index and 30-day learning plan, visual reference diagrams, and a Kubernetes-to-NIST mapping supplement. The goal is to connect security requirements to real platform implementations, assessment evidence, and risk decisions.

Intended readers: cybersecurity engineers, platform and DevSecOps practitioners, ISSOs, and prospective SCAs. Each volume can be read independently; use the master study plan for a guided sequence.

Public-use notice: This is an independently prepared educational reference. It is not an official publication of the U.S. Department of Defense, DISA, NIST, FedRAMP, or any other government agency, and does not represent authorization, accreditation, or compliance certification.

Accuracy and currency: Requirements, cloud authorization rules, control baselines, and vendor implementations can change. Control-to-tool relationships are illustrative, not automatic satisfaction of a requirement. Consult the current authoritative standards, program-specific instructions, selected assessment objectives, and system authorization boundary before applying this material.

Distribution: Shared for free educational use. Individual component documents may contain their own titles and pagination. External trademarks and product names remain with their respective owners. No government endorsement is implied.

Publication note: Review for sensitive information before publishing materials derived from actual employer systems. This edition is intended as a general educational reference.

How to navigate

The following page lists the starting PDF page for each section. PDF bookmarks also provide direct navigation. The study plan and some source sheets use their original standalone page numbering.

Contents

The page numbers below refer to this combined PDF. Source-volume page numbers are retained within each section.

Section	PDF page
Visual Reference: Seven-Step RMF	4–4
Visual Reference: Assessment, Roles & Boundaries	5–7
Visual Reference: Controls to Platform Tools	8–8
Master Index & 30-Day Study Plan	9–12
Volume 1 — RMF Foundations	13–19
Volume 2 — NIST SP 800-53 Rev. 5	20–26
Volume 3 — Security Control Assessment	27–34
Volume 4 — DoD RMF & DISA	35–42
Volume 5 — Continuous Monitoring & POA&Ms;	43–50
Volume 6 — Cloud & Kubernetes Compliance	51–58
Volume 7 — GRC & Authorization Frameworks	59–66
Volume 8 — Career & Interview Preparation	67–74
Volume 9 — Field Reference & Appendices	75–88
Volume 10 — Security Controls to Platform Technologies	89–102
Supplement — Kubernetes to NIST 800-53 Mapping	103–107

RISK MANAGEMENT FRAMEWORK

DoD RMF • Seven steps • NIST SP 800-37 Rev. 2

0 **PREPARE**

Establish context, roles, boundary, resources and strategy.

1 **CATEGORIZE**

Determine impact levels for confidentiality, integrity, availability.

2 **SELECT**

Select and tailor controls; document the security control baseline.

3 **IMPLEMENT**

Implement controls and describe them in the System Security Plan.

4 **ASSESS**

Use SAP and 800-53A methods; examine, interview, test; produce SAR.

5 **AUTHORIZE**

AO reviews risk and decides whether to authorize operation.

6 **MONITOR**

Track controls, changes, findings, POA&Ms and ongoing risk.

WHO DOES WHAT

ISSO: Maintains security posture, evidence, POA&Ms and RMF coordination.

SCA: Independently assesses controls and documents findings in the SAR.

AO: Makes the risk-based authorization decision.

CORE ARTIFACTS

SSP • SAP • SAR • POA&M • Continuous Monitoring Strategy

References: NIST SP 800-37 Rev. 2 | SP 800-53 Rev. 5 | SP 800-53A Rev. 5

Study reference • Follow current DoD Component guidance for operational use.

Security Control Assessment Workflow

From selected control objective to traceable SAR result | NIST SP 800-53A

1 Define scope and objectives

Boundary, baseline, enhancements, parameters

2 Plan assessment

SAP, procedures, sampling, access and constraints

3 Collect and validate evidence

Source, date, coverage, authenticity

4 Examine • Interview • Test

Use approved procedures; record observed results

5 Determine each objective

Satisfied / other supported determination

6 Document deficiencies

Criterion, condition, evidence, impact, scope

7 Issue SAR and support remediation

Report results; retest fixes as required

ASSESSOR CHECK: Can another assessor reproduce the result?

Keep the objective → evidence → determination → finding traceable.

RMF Roles & Artifact Handoffs

Typical accountability pattern | Responsibilities vary by DoD Component and system

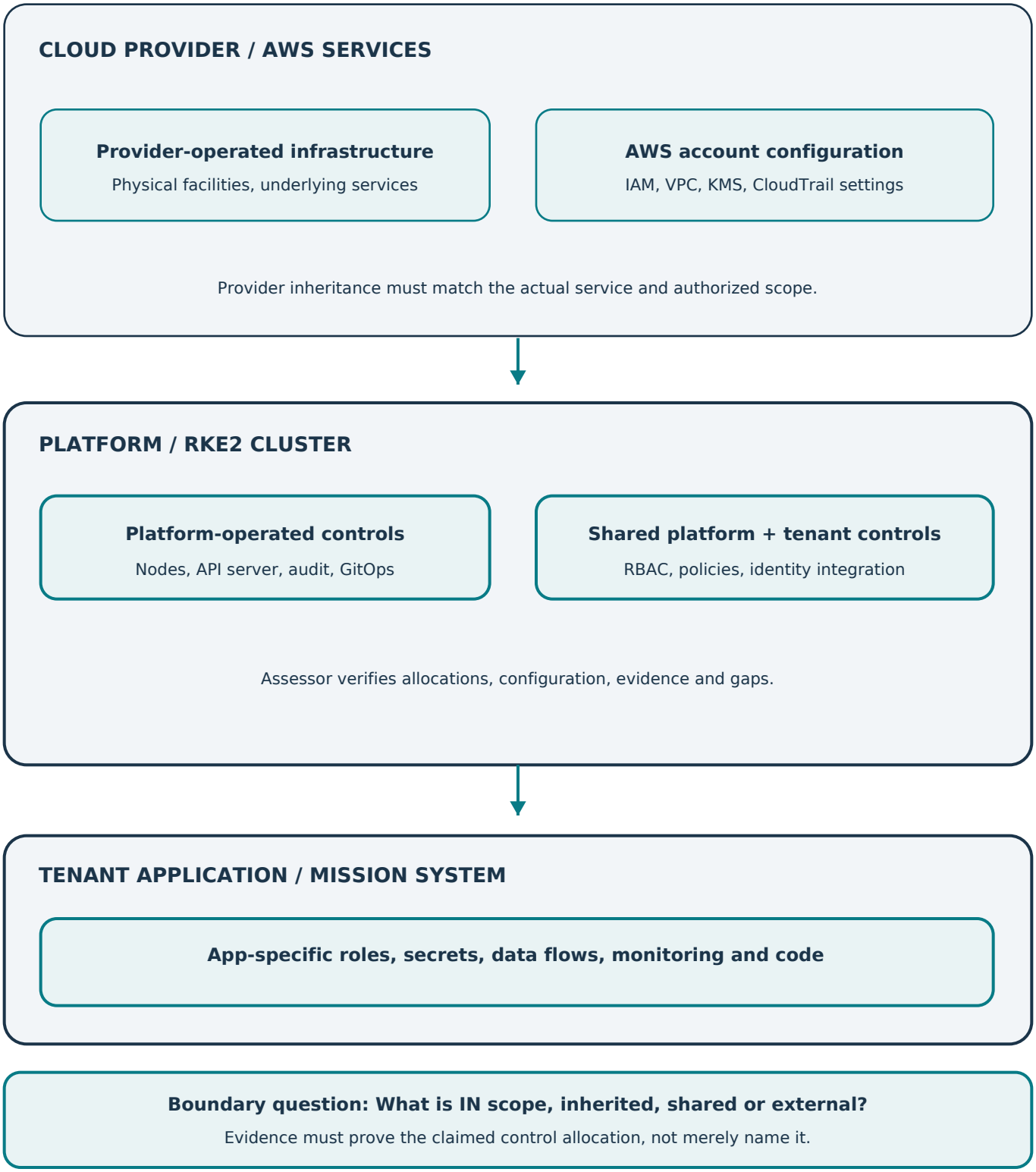
ENGINEER	ISSO	SCA	AO
IMPLEMENT CONTROLS			
Evidence + configs	Coordinate SSP	Review scope	Informed
PREPARE ASSESSMENT			
Technical access	Package / SSP	SAP + procedures	Informed
ASSESS CONTROLS			
Demonstrate	Coordinate	Examine / test	Informed
REPORT RESULTS			
Resolve facts	Track findings	SAR + findings	Review risk
REMEDIATE / MONITOR			
Fix + retest	POA&M + updates	Validate closure	Risk decision

Critical separation: implementation is not independent assessment.

AO makes the authorization risk decision; SCA reports assessed results.

Authorization Boundary & Control Inheritance

Illustrative AWS + RKE2 tenant platform | Determine responsibility per control



Security Controls → Platform Technologies

PERKFORGE | NIST requirement → capability → tools → implementation → assessor evidence

NIST CONTROL	SECURITY NEED	PLATFORM TOOLS	WHAT MUST WORK	SCA EVIDENCE / TEST
IA-2 / IA-5	Authenticate identities	Keycloak · OIDC/SAML	MFA, identity lifecycle, token policy	IdP config; MFA test; auth event logs
AC-2 / AC-3 / AC-6	Enforce least privilege	AWS IAM · K8s/Rancher RBAC	Approved roles; scoped permissions	Bindings; access reviews; denied-action test
AU-2 / AU-12 / AU-6	Generate and review audit	Alloy · Loki · CloudTrail	Capture required events; protect and review logs	Collector configs; raw events; review records
SI-4 / CA-7 / IR-5	Detect and respond	Grafana · Prometheus · SIEM	Meaningful alerts; triage and escalation	Alert rules; test alert; response ticket
IA-5 / SC-12 / SC-28	Protect secrets and keys	Vault · AWS KMS · External Secrets	Limit access; rotate; encrypt as required	Policies; rotation proof; encryption settings
CM-2 / CM-3 / CM-6	Control configuration	Fleet · GitLab · Terraform	Approved baseline; change control; drift detection	Merge approvals; desired vs actual state
RA-5 / SI-2 / SR-4	Identify and fix flaws	Trivy · Nessus · ECR scans	Scan in-scope assets; prioritize; retest	Coverage; findings; tickets; closure test
CP-9 / CP-10	Recover services and data	Velero · S3 · AWS Backup	Backups protected; recovery demonstrable	Schedules; retention; successful restore test

The assessor's test: a deployed tool is not proof of control effectiveness.

Trace selected assessment objective → in-scope configuration → observed behavior → dated evidence → determination.

Illustrative mappings only. Verify selected control enhancements, 800-53A objectives, boundary, inheritance and DoD-specific requirements.

Master Binder Index

Eight volumes • 62 printed pages • 30-day guided study • Letter size

Career destination: Security Control Assessor (SCA). Possible interim roles: ISSO or Cybersecurity Engineer. Use the page references below to study without reprinting the full standards.

HOW TO USE THIS BINDER

Study for 20–30 minutes daily. Read the assigned pages, answer the printed knowledge checks without looking, then spend 5 minutes explaining the material aloud as an engineer, an ISSO, and an SCA.

VOLUME DIRECTORY

Vol.	Title	Pages	Focus
1	RMF Foundations	7	RMF lifecycle, roles, artifacts, boundary, glossary
2	NIST SP 800-53 Rev. 5	7	Families, baselines, inheritance, controls, evidence
3	Security Control Assessment	8	800-53A methods, SAP, SAR, findings, AC-6
4	DoD RMF & DISA	8	eMASS, STIG/SRG, findings, impact levels
5	Continuous Monitoring & POA&Ms	8	Monitoring, evidence, remediation, change
6	Cloud & Kubernetes Compliance	8	RBAC, tenant isolation, AWS, audit, STIGs
7	GRC & Authorization Frameworks	8	FedRAMP, CMMC, risk decisions, categorization
8	Career & Interview Preparation	8	ISSO/SCA questions and mock assessments

Navigation: “V3 p.6” means printed Volume 3, page 6. The schedules reference the page number printed in each PDF, not a combined-binder page number.

Study outcome: Explain the RMF process, interpret controls, select assessment methods, document findings, and defend risk-oriented conclusions.

Detailed Topic Index

Locate a study sheet quickly. Page numbers refer to each volume's own PDF.

Volume	Pages	Topics
V1	3–7	Seven RMF steps; roles and independence; artifacts; boundary and categorization; glossary
V2	3–7	20 control families; baselines and tailoring; inheritance; control structure; evidence mapping
V3	2–4	SCA workflow; examine/interview/test; assessment objectives and determinations
V3	5–8	SAP; evidence traceability; SAR and findings; AC-6 mock assessment
V4	2–4	DoD RMF governance; eMASS; STIGs, SRGs and SCAP
V4	5–8	STIG findings and POA&Ms; IL2/IL4/IL5/IL6; RKE2 exercise; glossary
V5	2–4	Continuous monitoring strategy; evidence cadence; POA&M lifecycle
V5	5–8	Vulnerability and STIG remediation; significant change; SCA validation; AWS/RKE2 exercise
V6	2–4	Cloud assessment map; Kubernetes access; tenant isolation
V6	5–8	AWS inheritance; audit evidence; configuration/STIGs; RKE2 mock assessment
V7	2–4	FedRAMP/DoD RMF/CMMC comparison; cloud authorization; CUI and 800-171
V7	5–8	ATO/IATT/DATO; FIPS 199/200 and 800-60; boundaries; mock authorization review
V8	2–4	Career positioning; interview introduction; ISSO interview questions
V8	5–8	SCA interview questions; engineering-to-GRC; AC-6 exercise; interview drill

Authoritative reading companions: NIST SP 800-37 Rev. 2, SP 800-53 Rev. 5, SP 800-53A Rev. 5, SP 800-137; applicable DoD RMF guidance; DISA STIG/SRG publications. Verify current versions and program-specific requirements before applying in production.

Day	Read	Active recall / practice
1	V1 p.3	Sketch all seven RMF steps from memory.
2	V1 p.4	Contrast AO, ISSO, SCA, and system owner.
3	V1 p.5	Explain SSP vs SAP vs SAR vs POA&M.
4	V1 p.6–7	Draw an authorization boundary; quiz terms.
5	V2 p.3	Name 20 families and three examples.
6	V2 p.4	Explain baseline selection and tailoring.
7	V2 p.5	Distinguish common, hybrid, system-specific.
8	V2 p.6–7	Translate a control into evidence requests.
9	V3 p.2–3	Compare examine, interview, and test.
10	V3 p.4	Write an objective and determination.
11	V3 p.5	Outline a SAP for one control.
12	V3 p.6	Build an evidence traceability checklist.
13	V3 p.7	Draft a defensible assessment finding.
14	V3 p.8	Complete the AC-6 assessment exercise.
15	V4 p.2–3	Describe DoD RMF governance and eMASS.

WEEKLY CHECKPOINTS

Day 7: Describe the RMF lifecycle and why inherited controls need verified scope. Day 14: Explain how an SCA moves from assessment objective to evidence to finding.

30-Day Study Schedule · Days 16–30

Emphasis shifts from understanding RMF to practicing independent assessment.

Day	Read	Active recall / practice
16	V4 p.4–5	Explain STIG/SRG findings and remediation.
17	V4 p.6–8	Distinguish cloud ILs; review RKE2 case.
18	V5 p.2–3	Sketch continuous monitoring cadence.
19	V5 p.4–5	Write a sample POA&M entry.
20	V5 p.6–7	Explain significant change and validation.
21	V5 p.8	Work AWS/RKE2 monitoring scenario.
22	V6 p.2–4	Assess RBAC and tenant isolation.
23	V6 p.5–7	Assess AWS inheritance, logs, STIGs.
24	V6 p.8	Document an RKE2 SCA finding.
25	V7 p.2–4	Compare FedRAMP, DoD RMF, CMMC.
26	V7 p.5–7	Explain AO decisions and categorization.
27	V7 p.8	Complete authorization review scenario.
28	V8 p.2–4	Practice 60-second pitch and ISSO Q&A.
29	V8 p.5–7	Practice SCA Q&A and AC-6 case.
30	V8 p.8 + V3 p.7	Run mock interview; write one SAR finding.

FINAL SELF-ASSESSMENT

Without notes: (1) explain all seven RMF steps; (2) identify the roles responsible for implementing, maintaining, assessing, and accepting risk; (3) select examine/interview/test for AC-6; (4) describe a SAP and SAR; (5) defend a finding with evidence; (6) explain what makes a POA&M closure credible.

After day 30: Repeat weak topics, conduct a second mock assessment against AC-2 or AU-12, and practice answering interview questions with concise examples from your engineering experience.

PERKFORGE / STUDY SERIES

DoD RMF & Security Assessment

VOLUME 01 | RMF FOUNDATIONS

Career focus: Platform Engineering / DevSecOps → ISSO → Security Control Assessor (SCA).
Format: US Letter, black-and-white-friendly, one topic per sheet.

A compact field reference for understanding authorization decisions, RMF responsibilities, assessment evidence, and DoD-specific workflows.

STUDY METHOD

Read one sheet, explain it aloud without looking, answer its questions, then connect it to a system you know. Review missed questions the following day.

Educational study material, not an official DoD publication. Verify program-specific requirements against current governing guidance.

Contents & Study Plan

Volume 1 is intentionally short: four foundational reference sheets plus a glossary. Each page can be printed individually and placed behind a binder tab.

Page	Sheet	Practice focus
3	RMF Seven-Step Lifecycle	Explain the sequence and feedback loops
4	RMF Roles & Independence	Distinguish ISSO, SCA, AO, SO, ISSM
5	RMF Artifacts	Understand SSP, SAP, SAR, POA&M
6	Boundary & Categorization	Explain scope, information types, impact
7	Glossary & Fast Recall	Build fluency with key terms

15-MINUTE DAILY ROUTINE

Minutes 0-5: Read one sheet and study the diagram/table.
Minutes 5-10: Answer the knowledge checks without looking.
Minutes 10-15: Apply the concept to an AWS / Kubernetes platform.

READING MAP

RMF process: NIST SP 800-37 Rev. 2.
Controls: NIST SP 800-53 Rev. 5.
Assessment: NIST SP 800-53A Rev. 5.
Categorization: FIPS 199 and NIST SP 800-60.
DoD implementation: DoDI 8510.01 and applicable component guidance.

Study rule: Separate the control requirement, the system implementation, the assessment evidence, and the authorization decision. These are related but not interchangeable.

01 / RMF Seven-Step Lifecycle

The RMF is a risk-based system life-cycle process, not a one-time checklist.

Step	Purpose / principal output
0 PREPARE	Establish context, roles, risk strategy, and organization/system readiness.
1 CATEGORIZE	Determine security categorization based on information types and potential impacts.
2 SELECT	Select and tailor controls; document them in the SSP.
3 IMPLEMENT	Implement controls and document how they operate.
4 ASSESS	Assess control implementation/effectiveness; produce assessment results and SAR.
5 AUTHORIZE	AO makes risk-based authorization decision using the package.
6 MONITOR	Track changes, deficiencies, controls, and risk continuously.

HOW THE FLOW WORKS

PREPARE → CATEGORIZE → SELECT → IMPLEMENT → ASSESS → AUTHORIZE → MONITOR
Monitoring feeds new evidence, risks, and changes back into ongoing RMF activities; the process is iterative.

SCA LENS

An SCA focuses on Step 4, but needs Steps 0-3 to understand the boundary, controls, implementation, and assessment scope. Step 6 may trigger reassessment.

QUICK KNOWLEDGE CHECK

1. Which step produces an authorization decision, and who makes it?

2. Why can a significant system change lead to additional assessment?

Reference: NIST SP 800-37 Rev. 2, RMF Tasks and Roles.

02 / RMF Roles & Independence

Role assignments vary by organization. The table describes common RMF responsibilities, not an exclusive assignment of every task.

Role	Core responsibility
Authorizing Official (AO)	Senior official who accepts authorization risk and issues authorization decisions.
System Owner (SO)	Responsible for system operation, resources, and coordination of RMF activities.
ISSO	Supports day-to-day security posture, documentation, evidence, POA&Ms, and monitoring.
ISSM	Manages or oversees information system security program functions; organizational scope varies.
Security Control Assessor (SCA)	Plans/conducts or leads assessment activities and reports control assessment results.
Control Owner / Common Control Provider	Implements, operates, or provides controls that systems may inherit.

INDEPENDENCE: THE KEY DISTINCTION

SCA independence is organizational/functional, not necessarily a separate company. Required independence depends on risk, impact, governing policy, and the AO/organization. Avoid assessing your own implementation without appropriate safeguards.

PRACTICAL EXAMPLE

An ISSO coordinates evidence for Kubernetes AC-6. The SCA independently examines RBAC/IAM evidence and evaluates assessment objectives. The AO decides whether the residual risk is acceptable.

QUICK KNOWLEDGE CHECK

1. Who owns the final authorization decision?
2. Can an SCA work for the same contractor as the system team?

Reference: NIST SP 800-37 Rev. 2; NIST SP 800-53A Rev. 5.

03 / Core RMF Artifacts

Think of the authorization package as a defensible story: what the system is, what protections exist, what was assessed, and what risk remains.

Artifact	What it answers
SSP - System Security Plan	What is the boundary? Which controls apply? How are they implemented or inherited?
SAP - Security Assessment Plan	What will be assessed, by whom, using which methods, scope, and procedures?
SAR - Security Assessment Report	What was assessed? What evidence and results support the findings?
POA&M - Plan of Action & Milestones	What deficiencies remain, who owns remediation, and what are the milestones?
Continuous Monitoring Strategy	What will be monitored, at what frequency, and how will changes and findings be reported?

THE EVIDENCE CHAIN

Control requirement → implementation description → assessment objective → evidence → finding → remediation / risk decision

EXAMPLE: AC-6 / LEAST PRIVILEGE

SSP: describes Kubernetes RBAC and AWS IAM design.
SAP: specifies examine/interview/test procedures.
SAR: records results, supporting evidence, and deficiencies.
POA&M: tracks correction of excessive privileges, if needed.

QUICK KNOWLEDGE CHECK

1. Why is an SSP alone not proof a control is effective?

2. What is the difference between a SAR finding and a POA&M action?

Reference: NIST SP 800-37 Rev. 2; NIST SP 800-53A Rev. 5. Specific DoD templates/workflows may differ.

04 / Boundary & Categorization

Before assessing controls, know exactly what system is in scope and what mission/information impact it carries.

AUTHORIZATION BOUNDARY

The authorization boundary identifies the information system components, services, interfaces, and dependencies included in the authorization. It must be justified and documented; external services and inherited controls still require clear treatment.

FIPS 199 SECURITY OBJECTIVES

Objective	Question to ask
Confidentiality	What happens if information is disclosed without authorization?
Integrity	What happens if information is improperly modified or destroyed?
Availability	What happens if access or use is disrupted?

IMPACT LEVELS

For each information type, assess potential impact on each objective as Low, Moderate, or High. The system categorization applies the high-water-mark approach across information types/objectives, subject to applicable guidance. Do not confuse FIPS 199 impact levels with DoD cloud impact levels (IL4/IL5/IL6).

KUBERNETES / AWS EXAMPLE

Boundary exercise: Identify AWS accounts, VPCs, EKS/RKE2 clusters, worker nodes, IAM, ingress, logging, identity providers, CI/CD, data stores, and external services. Mark which are inside the boundary, outside but connected, or inherited/shared. Document the rationale.

QUICK KNOWLEDGE CHECK

1. Why does an inaccurate boundary undermine an assessment?
2. How is FIPS 199 High different from DoD Cloud IL5?

Reference: FIPS 199; NIST SP 800-60 Vols. I-II; NIST SP 800-37 Rev. 2.

05 / RMF Glossary & Fast Recall

Term	Meaning
ATO	Authorization to Operate: an AO decision permitting operation under stated terms.
AO	Authorizing Official: accountable for accepting authorization risk.
SCA	Security Control Assessor: assesses controls and reports results.
ISSO	Information System Security Officer: supports security operations and RMF activities.
SSP	System Security Plan: system, boundary, controls, and implementation.
SAP / SAR	Security Assessment Plan / Security Assessment Report.
POA&M	Plan of Action & Milestones: tracks deficiencies and corrective actions.
Common control	Control provided for inheritance by multiple systems.
Hybrid control	Control with shared responsibility for implementation.
Residual risk	Risk remaining after safeguards and responses.
eMASS	Enterprise Mission Assurance Support Service; DoD RMF workflow/repository tool.
STIG / SRG	DISA Security Technical Implementation Guide / Security Requirements Guide.

FIVE QUESTIONS AN SCA SHOULD ALWAYS ASK

1. What is the exact assessment objective?
2. What is the system boundary and who owns this control?
3. Which evidence is current, relevant, and trustworthy?
4. What do examine, interview, and test results actually demonstrate?
5. Can the conclusion be reproduced and defended?

OFFICIAL STARTING POINTS

NIST RMF: csrc.nist.gov/projects/risk-management
NIST publications: csrc.nist.gov/publications
DISA STIGs: public.cyber.mil/stigs/
DoD issuances: esd.whs.mil/DD/

Remember: An assessment finding is not the authorization decision. The assessor provides evidence-based results; the AO makes the risk decision.

PERKFORGE • PROFESSIONAL STUDY SERIES

NIST SP 800-53 REVISION 5

Volume 2 | Security & Privacy Controls

ISSO / Cybersecurity Engineer → Security Control Assessor

Purpose	Study focus
Understand the control catalog	Families, baselines, inheritance, tailoring, enhancements
Apply it in DoD environments	Control implementation, documentation, and assessment
Prepare for SCA work	Translate each control into defensible evidence and assessment objectives

Letter-size • Printer-friendly • Seven pages • Study aid, not official policy

Volume 2 | Study Map

A concise, practical bridge between engineering, ISSO responsibilities, and independent security control assessment.

Sheet	What you should be able to explain
1 • Control families	Identify the 20 families and what they cover
2 • Baselines	Explain low, moderate, high and tailoring
3 • Inheritance	Distinguish common, system-specific, and hybrid controls
4 • Control anatomy	Read base controls, enhancements, and parameters
5 • Evidence and assessment	Map implementation statements to 800-53A objectives

How to study (15 minutes daily)

Read one sheet, explain it aloud without looking, then apply its concepts to a Kubernetes/AWS example. Finish with the quick-check question. Revisit weak topics after two days.

Important boundaries

NIST SP 800-53 is a catalog of controls; it is not itself a certification or a fixed universal checklist. SP 800-53B defines federal control baselines. SP 800-53A provides assessment procedures. DoD requirements, overlays, and authorization guidance determine what applies to a particular system.

SCA mindset

For every control, ask: What is required? Who implements it? What is the authorization boundary? What evidence demonstrates the requirement? What would constitute a deficiency?

References: NIST SP 800-53 Rev. 5; SP 800-53B; SP 800-53A Rev. 5; SP 800-37 Rev. 2.

1 | The 20 Control Families

Memorize the family codes, but focus on what each family protects and how its controls can be assessed.

Code	Family	Code	Family
AC	Access Control	PE	Physical and Environmental Protection
AT	Awareness and Training	PL	Planning
AU	Audit and Accountability	PM	Program Management
CA	Assessment, Authorization, Monitoring	PS	Personnel Security
CM	Configuration Management	PT	PII Processing and Transparency
CP	Contingency Planning	RA	Risk Assessment
IA	Identification and Authentication	SA	System and Services Acquisition
IR	Incident Response	SC	System and Communications Protection
MA	Maintenance	SI	System and Information Integrity
MP	Media Protection	SR	Supply Chain Risk Management

THREE-ROLE LENS

Cybersecurity Engineer	ISSO	SCA
Implement technical controls (e.g., RBAC, logging, scanning).	Document implementation, ownership, evidence, and deficiencies.	Evaluate relevant objectives and corroborate evidence through examine/interview/test.

QUICK CHECK

Which families cover identity (IA), access permissions (AC), logging (AU), and security assessments (CA)?

References: NIST SP 800-53 Rev. 5, control family organization.

2 | Baselines and Tailoring

Baselines are starting points for selecting controls, not a shortcut for determining system-specific requirements.

Concept	Meaning
Low / Moderate / High	SP 800-53B provides baseline control selections associated with impact levels; these are tailored to the system.
Categorization	FIPS 199 uses potential impacts on confidentiality, integrity, and availability; system categorization informs baseline selection.
Tailoring	Apply overlays, scoping considerations, parameter assignments, compensating controls, and approved changes as appropriate.
Privacy baseline	SP 800-53B also provides a privacy control baseline; privacy considerations are not limited to one impact level.

Example: DoD cloud platform

An AWS-hosted platform is categorized, the applicable baseline and overlays are identified, and inherited controls from authorized providers are documented. The team must still implement and assess controls within its own responsibility.

THREE-ROLE LENS

Cybersecurity Engineer	ISSO	SCA
Deploy controls required by the tailored baseline.	Track selected controls, inheritance, implementation status, and deviations in the SSP.	Verify the assessed control set matches the approved baseline and tailoring decisions.

QUICK CHECK

Why can two systems with the same impact level have different final control selections?

References: FIPS 199; NIST SP 800-53B; NIST SP 800-37 Rev. 2.

3 | Control Inheritance

The boundary and provider responsibility determine who implements, documents, and assesses each portion of a control.

Type	Meaning	Example
Common	Implemented for multiple systems by a common control provider.	Enterprise physical security or centrally managed identity service.
System-specific	Implemented specifically for the system being assessed.	Application-level authorization checks.
Hybrid	Part common, part system-specific.	Cloud infrastructure protections plus tenant workload configuration.

Cloud shared responsibility is not automatic inheritance

A provider marketing statement or compliance certificate does not by itself establish that a particular control is inherited. Identify the provider, applicable authorization, implementation scope, consumer responsibilities, and supporting evidence.

Example: Kubernetes on AWS

The cloud provider may be responsible for data-center physical protections; the platform team may manage Kubernetes RBAC; an application team may enforce application roles. Record the exact allocation instead of labeling the entire control “inherited.”

THREE-ROLE LENS

Cybersecurity Engineer	ISSO	SCA
Configure the system-specific portions and integration points.	Maintain inheritance documentation, provider references, and consumer obligations.	Verify inheritance claims, applicability, and evidence for system-owned portions.

QUICK CHECK

What evidence would you request before accepting a claim that AC-2 is fully inherited?

References: NIST SP 800-53 Rev. 5; SP 800-37 Rev. 2; SP 800-53A Rev. 5.

4 | Reading a Control

Read the full control statement and enhancements before deciding what implementation or evidence is sufficient.

Part	What it means
Family and identifier	AC-6 = Access Control family, control 6 (Least Privilege).
Base control	The primary security/privacy requirement.
Enhancement	Additional requirement identified by a number, such as AC-6(1). Not every enhancement is selected.
Organization-defined parameter	A value or choice that must be assigned by the organization, such as a frequency or role.
Discussion / related controls	Interpretive context and relationships; do not substitute discussion for normative control text.

Practical example: AC-6

The assessor first confirms the approved selection of AC-6 and any enhancements, then identifies how least privilege is enforced across AWS IAM, Kubernetes RBAC, service accounts, and administrative workflows. A screenshot alone rarely proves ongoing effectiveness.

Common mistake

Treating a control family title as the full requirement. Always read the specific control text, selected enhancements, parameter assignments, and applicable overlays.

THREE-ROLE LENS

Cybersecurity Engineer	ISSO	SCA
Implement role and permission restrictions.	Document privilege design, approval, periodic review, and evidence location.	Check whether the defined assessment objectives are satisfied using appropriate methods.

QUICK CHECK

What is the difference between AC-6 and AC-6(1), and why does selection matter?

References: NIST SP 800-53 Rev. 5, AC-6 and its enhancements; SP 800-53B.

5 | From Control to Assessment

Your SCA transition: turn documented implementations into testable, evidence-backed assessment conclusions.

Stage	Example: AC-6 — Least Privilege
1. Scope	Confirm the authorization boundary, selected control/enhancements, and responsible components.
2. Read objectives	Use the applicable SP 800-53A assessment objectives and methods.
3. Examine	Inspect approved role definitions, IAM/RBAC configurations, access reviews, and procedures.
4. Interview	Ask administrators how elevated access is requested, approved, and revoked.
5. Test	With authorization and safe test accounts, verify that unapproved actions are denied.
6. Conclude	Document what was assessed, evidence, objective-level results, limitations, and deficiencies.

Evidence quality checklist

Is it relevant to the objective? Current for the assessment period? Traceable to the right system and boundary? Reliable and reproducible? Sufficient for the determination?

THREE-ROLE LENS

Cybersecurity Engineer	ISSO	SCA
Supply configurations and safe test support.	Coordinate access to evidence and track resulting remediation.	Select methods, evaluate evidence, record findings, and preserve independence.

QUICK CHECK

If an SSP says “least privilege enforced,” what additional evidence would you seek?

References: NIST SP 800-53A Rev. 5 (assessment methods and objectives); SP 800-53 Rev. 5; SP 800-37 Rev. 2.

VOLUME 03

Security Control Assessment

NIST SP 800-53A Rev. 5 | Practical SCA Study Guide

YOUR CAREER PATH
Cybersecurity Engineer / ISSO → Security Control Assessor (SCA) → Assessment Lead

A concise, letter-size reference for independent assessments, evidence quality, assessment plans, findings, and reporting. Illustrative examples are not substitutes for approved assessment procedures.

PRINT FORMAT: US LETTER • 8.5 × 11 IN • PORTRAIT

STUDY MAP

What an SCA actually does

An assessor determines whether security and privacy controls are implemented correctly, operating as intended, and producing the desired outcome with respect to meeting requirements. The SCA reports supported results; the Authorizing Official makes the authorization decision.

Assessment workflow

Scope → Plan → Collect evidence → Determine results → Report findings → Support remediation validation. Assessment work is iterative and risk-informed; exact sequencing and approval responsibilities depend on the program.

Six sheets in this volume

1. Assessment methods: Examine, Interview, Test
2. Assessment objectives and determination statements
3. Security Assessment Plan (SAP)
4. Evidence quality and traceability
5. Security Assessment Report (SAR) and findings
6. Practical assessment: AC-6 least privilege

Critical distinction
An implementation statement in the SSP is a claim. The assessor seeks sufficient, appropriate evidence to determine whether each applicable assessment objective is satisfied.

THREE-ROLE LENS

ENGINEER: Implements and explains security mechanisms.

ISSO: Maintains the SSP, coordinates evidence, tracks deficiencies.

SCA: Plans and performs objective, documented assessment activities.

QUICK KNOWLEDGE CHECK

Who determines control effectiveness? Who accepts residual risk?

Reference: NIST SP 800-53A Rev. 5; NIST SP 800-37 Rev. 2.

SHEET 1

Examine • Interview • Test

EXAMINE — Inspect evidence

Read policies, procedures, system security plans, architecture diagrams, audit logs, configurations, scan results, tickets, and other records. Ask whether the material is relevant, current, and attributable to the assessed system.

INTERVIEW — Validate understanding

Question system owners, administrators, security staff, and operators. Corroborate claims with other evidence where needed. Interview results alone may be insufficient for technical operating-effectiveness conclusions.

TEST — Observe actual behavior

Exercise or observe mechanisms using authorized procedures, safe accounts, and an approved assessment environment. Examples: test whether a restricted identity can perform a privileged action; verify audit-event generation.

AC-6 example
Examine: Kubernetes RoleBindings and IAM permissions.
Interview: access administrator on privilege approvals.
Test: using an authorized test identity, attempt an action outside the granted role and record the result.

THREE-ROLE LENS

ENGINEER: Provides configuration exports and safe test setup.

ISSO: Coordinates personnel, evidence, and assessment windows.

SCA: Chooses suitable methods, objects, depth, and coverage consistent with the assessment plan.

QUICK KNOWLEDGE CHECK

Why is a screenshot of a policy not proof that least privilege is enforced?

Reference: NIST SP 800-53A Rev. 5, assessment methods and objects.

SHEET 2

Objectives and determinations

SP 800-53A organizes assessment procedures around assessment objectives and determination statements. Assessors evaluate applicable statements using defined methods and objects, then record results according to the approved assessment approach.

A defensible assessment path

1. Identify applicable control and enhancement, including tailored parameters.
2. Read its exact 800-53A assessment objective and determination statements.
3. Identify assessment objects: specifications, mechanisms, activities, or individuals.
4. Select examine/interview/test procedures and appropriate depth/coverage.
5. Collect evidence and record objective-level determinations.
6. Document deficiencies and implications without overclaiming.

Important nuance
A control can have multiple determination statements. One passing configuration check does not automatically establish that the entire control is satisfied. Follow the applicable assessment procedure and organizational reporting conventions.

THREE-ROLE LENS

ENGINEER: Explains actual implementation and test constraints.

ISSO: Ensures implementation descriptions and evidence are accurate.

SCA: Makes evidence-based determinations against defined objectives, not personal preference.

QUICK KNOWLEDGE CHECK

What is the difference between a control statement and an assessment determination?

Reference: NIST SP 800-53A Rev. 5; NIST SP 800-53 Rev. 5.

SHEET 3

Security Assessment Plan (SAP)

The SAP documents what will be assessed and how. It aligns assessors, system stakeholders, and authorizing officials on scope and assessment execution before testing begins.

SAP essentials

System and scope: system identification, authorization boundary, components, environment, inherited controls, and exclusions.
Assessment basis: applicable control baseline, tailoring, enhancements, parameters, and assessment objectives.
Approach: methods, objects, sampling, depth, coverage, tools, interviews, and test procedures.
Execution: personnel, independence, schedule, rules of engagement, approvals, access, safety, and handling of sensitive evidence.
Outputs: documentation standards, findings process, and reporting deliverables.

SCA planning question
For a multi-tenant RKE2 platform, how will the assessor sample namespaces, service accounts, cluster roles, and AWS roles to justify conclusions across the assessed boundary?

THREE-ROLE LENS

ENGINEER: Identifies operational risk and supplies safe test access.

ISSO: Coordinates assessment readiness and artifact availability.

SCA: Defines assessment approach, objectives, methods, and documentation expectations.

QUICK KNOWLEDGE CHECK

Why should the SAP identify sampling and rules of engagement before tests?

Reference: NIST SP 800-53A Rev. 5; NIST SP 800-37 Rev. 2, Assess step.

SHEET 4

Evidence quality and traceability

Strong assessment evidence is relevant, credible, current, complete enough for the objective, and traceable to a specific system, configuration, time, and procedure.

Evidence quality checklist

Relevance: Does this prove the particular assessment statement?
Scope: Does it cover the actual authorization boundary and assessed components?
Provenance: Who or what generated it? Is its source trustworthy?
Currency: Was it collected during the applicable assessment period?
Repeatability: Could another assessor reproduce or independently validate it?
Protection: Is sensitive evidence stored, transferred, and retained appropriately?

Example: weak vs stronger

Weak: Screenshot of a Rancher role page with no date, cluster name, or user context.
Stronger: Time-stamped export identifying cluster, role and binding; associated access-request record; and documented authorized test results.

Traceability chain
Control → Assessment objective → Method / object → Evidence identifier → Determination → Finding (if applicable).

THREE-ROLE LENS

ENGINEER: Supplies accurate configuration and activity records.

ISSO: Maintains an evidence inventory and tracks gaps.

SCA: Validates sufficiency and provenance; records the basis for each determination.

QUICK KNOWLEDGE CHECK

Name two reasons a valid-looking screenshot might be insufficient evidence.

Reference: NIST SP 800-53A Rev. 5; organizational evidence-handling requirements.

SHEET 5

SAR, findings and remediation

The Security Assessment Report (SAR) communicates the assessment approach, results, identified deficiencies, and relevant risks to authorization stakeholders. The SAR is not the authorization decision.

What to document for a finding

Identity: control/enhancement and assessment objective.
Condition: what was observed, in which components and under what circumstances.
Criteria: the requirement or objective that was not met.
Evidence: exact records, commands, interviews, and dates supporting the conclusion.
Impact: plausible security consequence, exposure, and applicable risk context.
Disposition: recommended action or follow-up, as allowed by the reporting process.

From finding to POA&M;

Assessment findings inform risk analysis and remediation planning. System stakeholders typically own corrective actions and POA&M; updates; assessors may later validate remediation evidence or retest. Risk acceptance and authorization remain with designated officials.

Example finding (illustrative)
AC-6: A workload service account was bound to cluster-admin without a documented operational justification. Evidence: role binding export and access review. Impact: compromise of the workload could enable cluster-wide actions. Final risk characterization requires system context.

THREE-ROLE LENS

ENGINEER: Remediates approved technical deficiencies.

ISSO: Tracks POA&M; ownership, milestones, and evidence.

SCA: Documents objective findings and validates fixes when assigned.

QUICK KNOWLEDGE CHECK

What evidence should accompany a finding so another assessor can verify it?

Reference: NIST SP 800-53A Rev. 5; NIST SP 800-37 Rev. 2.

SHEET 6

Mini assessment: AC-6

Scenario: A DoD platform team states that Kubernetes tenant workloads and AWS roles follow least privilege. Your task is to assess applicable AC-6 objectives within the approved SAP.

Plan the assessment

Examine: access-control policy, SSP implementation statement, Kubernetes Roles/ClusterRoles, RoleBindings/ClusterRoleBindings, service-account permissions, AWS IAM role policies, access reviews, exceptions.
Interview: identity owner and platform administrator on privilege assignment, approval, review, and revocation.
Test: use approved test identities to verify access denial for unauthorized namespace and privileged operations; avoid disruptive production tests.

Record a determination

For each applicable 800-53A determination statement, record evidence ID, assessed object, method, observed result, and outcome under the approved assessment conventions. Document gaps separately; do not treat absent evidence as proof of a specific technical failure.

Practice prompt
You find one cluster-admin binding for a CI runner. The engineer says it is required for deployments. What additional evidence or tests would establish whether its privileges are necessary, constrained, reviewed, and consistent with the applicable AC-6 objectives?

THREE-ROLE LENS

ENGINEER: Demonstrates deployment mechanics and least-privilege alternatives.

ISSO: Provides approval history, exceptions, and reviews.

SCA: Tests and documents whether applicable objectives are satisfied.

QUICK KNOWLEDGE CHECK

Write a three-sentence finding: condition, evidence, and potential impact.

Reference: NIST SP 800-53A Rev. 5, AC-6 assessment procedure; NIST SP 800-53 Rev. 5, AC-6.

VOLUME 4
DoD RMF & DISA

A field guide for the Cybersecurity Engineer / ISSO to Security Control Assessor career path.

FOCUS
DoD RMF governance | eMASS | DISA STIGs and SRGs | findings and exceptions | DoD cloud impact levels

How to use this volume

Read one sheet at a time. For each topic, distinguish the authoritative requirement from local program procedure. Then ask what evidence an independent assessor would need.

Contents

2. DoD RMF governance and decision authority
3. eMASS and the authorization package
4. DISA STIGs, SRGs, and SCAP
5. Findings, severity, exceptions, and POA&Ms;
6. DoD cloud impact levels and boundaries
7. Practical assessment scenario
8. Glossary and quick knowledge check

Reference: DoDI 8510.01; NIST SP 800-37 Rev. 2; NIST SP 800-53A Rev. 5. Verify current agency/component guidance.

DoD RMF Governance

DoD implements RMF under DoDI 8510.01, with component-level policies and procedures. RMF roles and exact approval chains depend on the program and DoD component.

Core decision and assessment relationships

Role	Principal responsibility
Authorizing Official (AO)	Makes authorization decisions and accepts residual risk within delegated authority.
System Owner (SO)	Accountable for system mission, resources, implementation and authorization support.
ISSM / ISSO	Coordinate security program, artifacts, monitoring, and control status as assigned.
Security Control Assessor (SCA)	Assesses controls and reports results; required independence depends on the assessment context.
Common Control Provider	Provides shared controls and evidence for inheritance.

Remember the distinction

Assess != Authorize. The SCA reports assessment results and risk information. The AO makes the authorization decision. An ATO does not mean zero risk.

THREE-ROLE LENS
Cybersecurity Engineer: implements technical safeguards and supplies evidence.
ISSO: maintains documentation and coordinates authorization workflows.
SCA: evaluates whether controls meet assessment objectives using evidence.

Knowledge check

Who accepts authorization risk: SCA or AO? Why is independence important?

Reference: DoDI 8510.01; NIST SP 800-37 Rev. 2, RMF roles and steps.

eMASS & Authorization Package

eMASS is a DoD workflow and repository used for RMF-related security authorization information. It is not the source of the security requirement itself; policy, control baselines, and approved program procedures govern those.

Typical package contents

Artifact / record	What to look for
SSP	System boundary, control implementation descriptions, inheritance and responsibilities.
SAP	Assessment scope, objectives, methods, sampling, schedule, and rules of engagement.
SAR	Assessment results, findings, supporting evidence, and risk-related observations.
POA&M;	Weaknesses, planned remediation, owners, milestones, and status.
Monitoring records	Scan results, change assessments, updates, and ongoing authorization evidence.

Quality checks before assessment

Does the system inventory match the boundary? Are inherited controls identified? Are evidence dates and owners traceable? Do open weaknesses align with assessment results and remediation records?

THREE-ROLE LENS
Cybersecurity Engineer: exports accurate configurations, logs and test artifacts.
ISSO: maintains package quality, workflow status and evidence currency.
SCA: tests evidence sufficiency and reports gaps without merely trusting a green status.

Knowledge check

If a control is marked implemented but no current evidence exists, what should an assessor do?

Reference: DoDI 8510.01; NIST SP 800-37 Rev. 2; local eMASS procedures vary.

DISA STIGs, SRGs & SCAP

DISA publishes Security Technical Implementation Guides (STIGs) and Security Requirements Guides (SRGs). They support secure configuration and technical requirement assessment. Applicability depends on technology, environment and governing policy.

Know the vocabulary

Term	Meaning
SRG	Security requirements for a technology class or subject area; can inform STIGs.
STIG	Technology-specific security configuration and verification guidance.
Rule / check	An individual technical requirement and its check / fix information.
SCAP	Standards-based automation content and protocols; supported checks vary.
Manual check	Human review or test needed where automated scans are insufficient.

Assessor workflow

1 Determine applicability and approved benchmark/version. 2 Inspect check text and evidence. 3 Verify reported status. 4 Record exceptions and trace findings to applicable controls and risk processes.

A scanner result is evidence, not necessarily a final assessment conclusion. False positives, false negatives, compensating controls and non-applicability require documented analysis.

THREE-ROLE LENS
Cybersecurity Engineer: hardens systems and remediates failed checks.
ISSO: tracks STIG posture, exceptions and corrective actions.
SCA: validates selected checks and whether supporting evidence is sufficient.

Knowledge check

Why might a STIG scan marked “pass” still require assessor follow-up?

Reference: DISA Cyber Exchange: public.cyber.mil/stigs/; NIST SP 800-53A Rev. 5.

Findings, Severity & Exceptions

A STIG check result, a control assessment finding, a vulnerability and a POA&M; item are related but not interchangeable. Record the specific deficiency and the decision process that applies.

STIG results and severity

Item	How to interpret it
CAT I / II / III	STIG vulnerability categories reflecting severity conventions; CAT I is most severe.
Open	Requirement not satisfied based on the check and evidence.
Not a Finding	Requirement satisfied based on verified evidence.
Not Applicable	Check does not apply, with a defensible rationale.
Exception / deviation	Must follow the applicable formal approval and risk-handling process; not a casual waiver.

From deficiency to risk record

Observe failed requirement → Validate applicability and evidence → Document technical impact and affected assets → Route for required risk handling / POA&M; → Verify remediation or authorized disposition.

Important: STIG CAT ratings do not automatically equal a NIST control risk determination or an AO authorization decision. Follow applicable program risk procedures.

THREE-ROLE LENS
Cybersecurity Engineer: corrects the vulnerability or implements approved mitigation.
ISSO: tracks ownership, milestones, approvals and closure evidence.
SCA: checks whether the weakness is accurately characterized and whether closure evidence is persuasive.

Knowledge check

What would justify marking a STIG requirement Not Applicable?

Reference: DISA STIG guidance; DoDI 8510.01; program/component vulnerability and POA&M; procedures.

DoD Cloud Impact Levels

DoD Cloud Computing Security Requirements Guide (CC SRG) establishes cloud security requirements and impact-level concepts. Impact levels are not simply equivalent to FIPS 199 Low / Moderate / High.

Quick orientation

Level	High-level orientation
IL2	Generally public / non-controlled unclassified DoD information under applicable SRG requirements.
IL4	Controlled unclassified information (CUI) and other information requiring IL4 protections, as applicable.
IL5	More sensitive CUI and mission-critical unclassified workloads under IL5 requirements.
IL6	Classified information up to SECRET, under applicable classified-cloud authorization rules.

What assessors actually verify

Confirm the data classification and mission requirements, authorization boundary, approved hosting environment, inherited controls, identity design, encryption, connectivity, tenancy, and documented customer-versus-provider responsibilities.

Do not infer authorization from a marketing claim. Verify the specific cloud service offering, approved impact level, boundary, services, and conditions of use through the appropriate authorization documentation.

THREE-ROLE LENS
Cybersecurity Engineer: configures compliant platform and workload isolation.
ISSO: maintains boundary, inheritance, data handling and authorization documentation.
SCA: checks whether the claimed hosting level and inherited safeguards apply to this actual system.

Knowledge check

Can an IL5-authorized provider automatically make every deployed workload IL5-authorized? Explain.

Reference: DISA DoD Cloud Computing SRG; current DoD cloud authorization and component guidance. Impact-level descriptions are simplified study summaries.

Mini Assessment: RKE2 Platform

Scenario: A DoD contractor operates an RKE2 platform in an approved cloud environment. The SSP states that Kubernetes tenant access is restricted, hosts follow DISA STIGs, and the platform inherits physical security controls.

Your assessment plan (sample)

Claim	Examine / Interview / Test
Tenant isolation	Examine namespaces, RBAC, network policy and tenant design; interview administrators; test access with approved identities.
Host hardening	Examine approved STIG baseline, scan outputs, manual checks and exception approvals; sample hosts.
Inherited controls	Examine provider authorization scope and customer responsibility matrix; interview system owner.
Package accuracy	Compare SSP boundary and inventory to deployed resources and current evidence.

Example finding language

Observation: A sampled tenant service account has a ClusterRoleBinding granting cluster-admin privileges.
Evidence: Approved read-only RBAC export, date, asset and interview notes.
Assessment: Evaluate against applicable AC-6 objectives, system design and approved assessment procedures; document conclusion and risk context.

Your role

Engineer: propose least-privilege design. ISSO: update control narrative and remediation record. SCA: independently validate evidence, assessment objective and closure.

Knowledge check

What additional evidence would you need before concluding AC-6 is not satisfied?

Reference: NIST SP 800-53 Rev. 5, AC-6; NIST SP 800-53A Rev. 5; applicable DISA STIGs.

Quick Glossary & Review

Term	Memory cue
ATO	Authorization to Operate: AO decision with stated conditions and risk.
AO	Authorizing Official: risk acceptance and authorization decision.
SCA	Security Control Assessor: independent evaluation as required.
SSP / SAP / SAR	Plan for system security / plan for assessment / report of assessment.
POA&M;	Tracked weaknesses and corrective-action milestones.
STIG / SRG	Technical implementation guidance / security requirements guide.
CC SRG	DoD Cloud Computing Security Requirements Guide.
Inheritance	Controls supplied wholly or partly by a common control provider.

Five-minute self-test

1. How does the SCA role differ from the AO role?
2. Why is eMASS status not proof of control effectiveness?
3. What evidence supports a Not Applicable STIG disposition?
4. What must you check before relying on inherited cloud controls?
5. What is the distinction between a STIG CAT and an assessment finding?

Authoritative starting points

DoDI 8510.01 — esd.whs.mil
DISA Cyber Exchange — public.cyber.mil/stigs/
NIST SP 800-37 — csrc.nist.gov/pubs/sp/800/37/r2/final
NIST SP 800-53A — csrc.nist.gov/pubs/sp/800/53/a/r5/final

Study habit: Explain each term from the Engineer, ISSO and SCA perspectives. Confirm the current version of every authoritative reference before applying it to a live DoD system.

Continuous Monitoring & POA&Ms

ISSO readiness / SCA assessment skills / Engineering evidence

VOLUME 05

FROM AUTHORIZATION TO ONGOING ASSURANCE

THE CORE IDEA

• An authorization decision is not the end of RMF. Monitor security controls, track changes, identify weaknesses, and communicate risk throughout the system life cycle.

• A POA&M documents planned corrective action for an identified weakness; it does not, by itself, eliminate or accept the risk.

IN THIS VOLUME

• 02 Continuous monitoring strategy and governance

• 03 Evidence cadence, metrics, and ongoing assessments

• 04 POA&M lifecycle and defensible entries

• 05 Vulnerability management and STIG remediation

• 06 Significant changes, impact analysis, and authorization

• 07 SCA validation of remediation and risk reporting

• 08 Practical RKE2 / AWS case study and quick checklist

STUDY METHOD: Read one sheet, explain it aloud, then answer its knowledge check.

Continuous Monitoring Strategy

What is monitored, how often, by whom, and what triggers action

MONITORING LOOP

- Define control monitoring priorities and assessment frequencies based on risk and organizational policy.
- Collect operational and security data; assess selected controls; analyze findings and changes.
- Update security posture and risk records; report to responsible officials; take corrective action.

WHAT THE STRATEGY SHOULD DEFINE

- Control and system scope, metrics, data sources, roles, responsibilities, and reporting paths.
- Assessment frequency and triggers; automated and manual collection methods; review and escalation thresholds.
- How significant changes, vulnerabilities, POA&Ms, and authorization status are handled.

THREE-ROLE LENS

- ENGINEER: Instrument logging, scanning, inventory, and configuration evidence.
- ISSO: Coordinate collection, maintain records, track deadlines, and brief stakeholders.
- SCA: Evaluate whether monitoring evidence supports control effectiveness and whether deficiencies persist.

KNOWLEDGE CHECK

- Who owns monitoring decisions, and how is the AO informed of material changes?

REFERENCES: NIST SP 800-37 Rev. 2; NIST SP 800-137

Evidence, Metrics & Assessment Cadence

Monitoring is more than running a scanner

EVIDENCE TYPES

- Technical: configuration exports, audit records, scan results, IAM reviews, patch status.
- Procedural: approved policies, review records, tickets, change approvals, training records.
- Assessment: test results, interviews, sampling notes, and links to applicable control objectives.

EXAMPLE METRICS

- Overdue high-risk findings; time to remediate; percentage of privileged accounts reviewed.
- Scan coverage and freshness; missing logs; exceptions due for review; unapproved configuration drift.
- Metrics must be defined and interpreted: a green dashboard is not proof every control is effective.

THREE-ROLE LENS

- ENGINEER: Produce accurate, timestamped artifacts with system and asset identity.
- ISSO: Maintain evidence schedules, ownership, freshness, and traceability to controls.
- SCA: Test sufficiency and reliability; sample evidence and verify claims where authorized.

KNOWLEDGE CHECK

- Why might a 30-day-old screenshot be weak evidence for a rapidly changing control?

REFERENCES: NIST SP 800-53A Rev. 5; NIST SP 800-137

POA&M Lifecycle

Track weaknesses from discovery through verified closure

SEVEN PRACTICAL STAGES

- 1. Identify the weakness and its source (assessment, scan, incident, audit).
- 2. Describe affected system/assets, impact, and relevant controls.
- 3. Assign an accountable owner and document planned corrective actions.
- 4. Establish milestones and realistic dates under governing policy.
- 5. Track status, blockers, interim safeguards, and overdue items.
- 6. Collect remediation evidence and validate effectiveness.
- 7. Close only through the required approval/validation workflow.

STRONG POA&M ENTRY

- Finding: Unauthorized wildcard permission in tenant RoleBinding.
- Scope: Tenant namespace and affected service account; map to relevant AC controls.
- Action: Replace wildcard with scoped verbs/resources; review related bindings.
- Evidence: Before/after manifests, approved change, authorized access tests.

THREE-ROLE LENS

- ENGINEER: Implement correction and provide test evidence.
- ISSO: Own tracking quality, milestones, status, and coordination.
- SCA: Independently validate corrective action when assigned and permitted.

KNOWLEDGE CHECK

- Does an approved POA&M automatically mean the residual risk is accepted? Why not?

REFERENCES: NIST SP 800-37 Rev. 2; DoD program policy

Vulnerability Management & STIGs

Prioritize, remediate, document, and verify

END-TO-END WORKFLOW

- Inventory assets and applicable STIG/SRG requirements; scan and manually validate as needed.
- Triage findings for applicability, severity, exposure, mission impact, and false positives.
- Remediate, mitigate, or document exceptions according to applicable authorization rules.
- Rescan and validate results; update tickets, POA&Ms, and risk reporting.

IMPORTANT DISTINCTIONS

- A scanner result is evidence to analyze, not an automatic final assessment determination.
- A STIG CAT severity and a system-specific risk determination are related but not identical.
- A compensating measure must be evaluated; it is not a substitute for documenting the weakness.

THREE-ROLE LENS

- ENGINEER: Apply approved patches, hardened settings, and configuration changes.
- ISSO: Coordinate scan cycles, owners, POA&Ms, and evidence submissions.
- SCA: Validate applicability, test outcomes, and sufficiency of remediation evidence.

KNOWLEDGE CHECK

- How would you document a STIG finding that is technically not applicable?

REFERENCES: DISA STIG guidance; NIST SP 800-53A Rev. 5

Significant Changes & Authorization

When routine maintenance becomes a risk decision

CHANGES THAT WARRANT SCRUTINY

- Boundary or hosting changes; major architectural changes; new external connections.
- New identity provider or trust relationships; substantial data-flow or sensitivity changes.
- Changes affecting inherited controls, mission impact, or security control effectiveness.

DECISION FLOW

- 1. Record the change and its security impact analysis.
- 2. Identify affected controls, evidence, dependencies, and authorization conditions.
- 3. Determine required reassessment and reporting using applicable DoD policy.
- 4. Escalate significant risk to designated officials; obtain decisions before proceeding where required.

THREE-ROLE LENS

- ENGINEER: Document design, rollout, rollback, and technical security impacts.
- ISSO: Coordinate impact analysis, package updates, and required notifications.
- SCA: Assess affected controls and report findings; do not assume the AO role.

KNOWLEDGE CHECK

- Would moving authentication from Okta to self-hosted Keycloak warrant impact analysis?

REFERENCES: NIST SP 800-37 Rev. 2; applicable DoD RMF guidance

SCA Remediation Validation

Evidence must demonstrate the deficiency was addressed

ASSESSOR VALIDATION CHECKLIST

- Trace the original finding to a specific assessment objective and affected assets.
- Inspect change records, new configurations, and control implementation narrative.
- Interview responsible personnel if process details or scope remain unclear.
- Perform approved tests or review credible test results; check for regression.
- Document conclusion, residual limitations, and whether finding status should change.

EXAMPLE: AC-6 LEAST PRIVILEGE

- Original finding: Service account has cluster-admin privileges without justification.
- Remediation claim: RoleBinding removed and scoped Role/RoleBinding deployed.
- Validation: Examine effective bindings; test permitted and denied actions with approved test identity; confirm no alternate privilege path in scope.

THREE-ROLE LENS

- ENGINEER: Supply before/after configuration and test artifacts.
- ISSO: Keep evidence, POA&M, and SSP aligned and route for validation.
- SCA: Document independent, objective-based determination with reproducible evidence.

KNOWLEDGE CHECK

- What evidence proves the privilege is actually restricted, not merely documented?

REFERENCES: NIST SP 800-53A Rev. 5

RKE2 + AWS: Practice Scenario

Apply the full continuous monitoring cycle

SCENARIO

• A monthly review finds that a tenant workload service account can read Secrets outside its intended application scope. A cluster upgrade is planned next week.

WORK THE CASE

• ENGINEER: Identify effective RBAC permissions; fix access; test permitted and denied requests; preserve evidence.

• ISSO: Record weakness, affected controls/assets, remediation milestones, interim safeguards, and status; assess upgrade/change implications.

• SCA: Evaluate original and corrected configurations; examine, interview, and test as appropriate; document whether assessment objectives are met.

DESK CHECKLIST

• [ ] System boundary and affected assets identified

• [ ] Control objective and weakness traceable

• [ ] Risk and escalation documented

• [ ] Owner, action, milestone, and due date recorded

• [ ] Remediation evidence retained and reviewed

• [ ] Required reassessment/closure approvals completed

KNOWLEDGE CHECK

• What would you ask the system owner before recommending closure?

REFERENCES: NIST SP 800-53A Rev. 5; NIST SP 800-137

VOLUME 6

Cloud & Kubernetes Compliance

AWS • RKE2 / Kubernetes • NIST SP 800-53 Rev. 5

CAREER PATH

Cybersecurity Engineer / ISSO → Security Control Assessor (SCA)

Eight letter-size study pages. Technical examples are illustrative, not universal DoD assessment procedures. Always use the approved system baseline, assessment plan, organizational policy, and current DoD guidance.

01 | Cloud Security Assessment Map

Cloud control assessment connects mission requirements, authorization boundary, inherited services, technical configuration, and operational evidence.

Traceability chain

FROM REQUIREMENT TO CONCLUSION

Selected control and enhancement → organization-defined parameters → implementation statement → assessment objective → evidence and method → determination and finding.

Common cloud assessment targets

• Identity: AWS IAM, federation, Kubernetes RBAC, workload identities.

• Network: VPC routes, security groups, Kubernetes NetworkPolicies, ingress and egress.

• Platform: RKE2 configuration, node hardening, admission controls, secrets handling.

• Operations: logging, change management, vulnerability scanning, backups, incident response.

Assessment boundary questions

• Which AWS accounts, regions, clusters, namespaces, and managed services are in scope?

• Which controls are inherited, shared, hybrid, or system-specific?

• What evidence proves the control is operating in the deployed environment?

Three-role perspective

ENGINEER: Create and maintain secure configurations and automation.

ISSO: Maintain accurate SSP statements, ownership, and evidence inventory.

SCA: Select assessment methods and determine whether objectives are satisfied.

KNOWLEDGE CHECK

Why is a Kubernetes YAML manifest alone insufficient to prove a control is effective?

References: NIST SP 800-37 Rev. 2; SP 800-53 Rev. 5; SP 800-53A Rev. 5.

02 | Kubernetes Access Control

Representative controls: AC-2 Account Management, AC-3 Access Enforcement, AC-6 Least Privilege, IA-2 Identification and Authentication.

Inspect the effective permissions

• Map IdP groups → Rancher roles → Kubernetes Roles/ClusterRoles → bindings.

• Review service accounts, workload tokens, impersonation, and privileged break-glass access.

• Check wildcard verbs/resources, cluster-admin grants, and cross-namespace permissions.

• Verify joiner/mover/leaver workflows, periodic reviews, and privilege removal.

EXAMINE • INTERVIEW • TEST

Examine role definitions and access-review records; interview identity and platform owners; test with approved nonproduction identities or read-only authorization checks. A binding listing is not proof that every permission is appropriately scoped.

Illustrative commands (authorized use only)

```
kubectl auth can-i --list --as=<test-user> -n <ns>
kubectl get rolebindings,clusterrolebindings -A
```

Three-role perspective

ENGINEER: Implement RBAC, identity federation, and access automation.

ISSO: Maintain account-management procedures and access review evidence.

SCA: Evaluate authorization outcomes and whether access restrictions meet assessment objectives.

KNOWLEDGE CHECK

What evidence would show that a tenant cannot read secrets in another namespace?

References: NIST SP 800-53 Rev. 5: AC, IA families; SP 800-53A Rev. 5.

03 | Tenant Isolation & Resource Boundaries

A namespace is an administrative boundary, not by itself a strong security boundary.

Isolation layers

• API authorization: namespace-scoped RBAC and restricted cluster-scoped permissions.

• Network: default-deny policies plus required ingress/egress; verify CNI enforcement.

• Workload: Pod Security Admission, seccomp, Linux capabilities, node hardening.

• Resources: ResourceQuota and LimitRange; monitor capacity and noisy-neighbor effects.

• Secrets and storage: CSI permissions, encryption, service-account scope, volume access.

IMPORTANT DISTINCTION

ResourceQuota constrains consumption; it does not provide confidentiality isolation. NetworkPolicy enforcement depends on the installed networking implementation. Node and kernel sharing remain relevant to tenant risk.

Assessment scenario

Tenant A should not reach Tenant B database. Examine policy objects and CNI behavior, interview the network owner, and perform approved connectivity tests from a representative tenant workload.

Three-role perspective

ENGINEER: Design and implement layered tenant boundaries.

ISSO: Document intended isolation and track exceptions or weaknesses.

SCA: Assess whether configured and effective boundaries satisfy selected controls.

KNOWLEDGE CHECK

Why are namespace separation and quotas insufficient as the sole isolation strategy?

References: NIST SP 800-53: AC-3, AC-4, SC-7, SC-39 as applicable; Kubernetes security documentation.

04 | AWS Shared Responsibility & Inheritance

A provider operating a service does not automatically transfer every customer control obligation to that provider.

Responsibility categories

• Provider-managed: physical facilities and underlying infrastructure controls, per service and authorization scope.

• Customer-managed: identities, data classification, configuration, application controls, and many monitoring activities.

• Shared/hybrid: controls whose objectives require both provider and customer implementation.

ASSESS INHERITANCE

Identify the specific authorized service, applicable boundary, provider control implementation, and customer-responsibility statements. Record which control portions are inherited and which require system evidence.

Evidence examples

• AWS account inventory, region and service inventory, and approved architecture diagrams.

• Applicable provider authorization documentation and customer responsibility matrix.

• CloudTrail/CloudWatch configuration, IAM policies, encryption settings, and review records.

• Service-specific configuration and evidence for customer-operated workloads.

Three-role perspective

ENGINEER: Configure AWS services and maintain infrastructure as code.

ISSO: Map inheritance and document residual customer responsibilities in the SSP.

SCA: Validate claimed inheritance and independently assess remaining customer responsibilities.

KNOWLEDGE CHECK

Why does “AWS is authorized” not establish that your application meets AC-6?

References: NIST SP 800-37 Rev. 2; NIST SP 800-53 Rev. 5; applicable AWS authorization package and service responsibility documents.

05 | Audit Logging & Evidence

Representative controls: AU-2 Event Logging, AU-6 Audit Record Review, AU-9 Protection of Audit Information, AU-12 Audit Record Generation.

Follow the event path

LOGGING PIPELINE

AWS / Kubernetes / RKE2 / application events → collection → protected transport → centralized retention → review and alerting → incident or remediation record.

Assess configuration and operation

• Confirm selected event types, log sources, retention, and time synchronization requirements.

• Inspect EKS/RKE2 control-plane and Kubernetes audit configuration as applicable.

• Verify access controls and integrity protections for stored audit data.

• Sample recent events and review records; confirm alerts lead to documented response.

• Check gaps: disabled sources, dropped events, unmonitored accounts, and retention failures.

Evidence quality checklist

• Timestamp and collection period; environment and system identity.

• Source of truth, owner, and collection method.

• Link to exact assessment objective and stated parameter.

• Repeatable result and protection against alteration.

Three-role perspective

ENGINEER: Configure telemetry, storage, alerts, and retention.

ISSO: Track evidence collection, review cadence, and POA&Ms.;

SCA: Evaluate both audit mechanisms and demonstrated operational review.

KNOWLEDGE CHECK

Does a screenshot showing “logging enabled” prove AU-6 is satisfied? Why not?

References: NIST SP 800-53 Rev. 5: AU family; SP 800-53A Rev. 5.

06 | Configuration, STIGs & Vulnerabilities

Representative controls: CM-2 Baseline Configuration, CM-6 Configuration Settings, RA-5 Vulnerability Monitoring and Scanning, SI-2 Flaw Remediation.

What to examine

• Documented and approved baseline for nodes, containers, cloud resources, and cluster components.

• Applicable DISA STIGs/SRGs, documented applicability decisions, and deviations.

• Authenticated scan coverage, scanner currency, finding reconciliation, and remediation status.

• GitOps change approvals, drift detection, exception handling, and patch verification.

FINDING ≠ RISK ACCEPTANCE

A scan finding, a POA&M entry, and an authorization risk decision are different records/actions. A claimed false positive or not-applicable status needs defensible justification and approval per governing process.

Illustrative assessment question

The team provides a clean node scan but the running container image has critical vulnerabilities. Does the scan cover the relevant assessment scope? Identify missing evidence before concluding.

Three-role perspective

ENGINEER: Implement hardening and fix flaws.

ISSO: Maintain scans, exceptions, remediation plans, and change evidence.

SCA: Verify scope, reproducibility, remediation evidence, and findings.

KNOWLEDGE CHECK

What additional evidence is needed before closing a remediated vulnerability finding?

References: NIST SP 800-53 Rev. 5: CM, RA, SI families; DISA STIG/SRG guidance applicable to the system.

07 | Mini SCA Exercise: RKE2 on AWS

Scenario: A DoD platform claims least privilege, namespace isolation, and audit coverage. You are assigned an authorized assessment under an approved SAP.

Claims and evidence presented

• AC-6: RBAC exports and Rancher role screenshots.

• AC-3 / SC-7: NetworkPolicy YAML and namespace inventory.

• AU-12 / AU-6: Audit settings and dashboard screenshots.

• CM-6 / RA-5: Node STIG results and monthly scan summary.

Your assessment workflow

• 1. Confirm control selection, enhancements, parameters, boundary, and assessment objectives.

• 2. Plan examine/interview/test procedures, sampling, and approved access.

• 3. Request current, attributable, and scope-complete evidence.

• 4. Evaluate effectiveness: permissions, network enforcement, audit events, review records.

• 5. Record objective-level determinations, limitations, findings, and evidence references.

SAMPLE FINDING LANGUAGE

“Evidence did not demonstrate that tenant network restrictions were enforced in the assessed cluster. Policy manifests were provided, but effective CNI enforcement and representative traffic tests were not evidenced. Assessment objective determination remains unresolved pending additional evidence.”

Career lens

Engineer: fixes the gap. **ISSO:** tracks it and maintains authorization evidence. **SCA:** documents the defensible assessment result and validates remediation when assigned.

KNOWLEDGE CHECK

Which missing evidence would you request first, and how would you avoid assuming failure solely from missing documentation?

References: NIST SP 800-53A Rev. 5; SP 800-37 Rev. 2; approved organizational SAP and DoD guidance.

PERKFORGE | DOD RMF & SECURITY ASSESSMENT

VOLUME 7

GRC & Authorization Frameworks

FedRAMP • DoD RMF • CMMC • Authorization Decisions

STUDY PATH	PURPOSE
Cybersecurity Engineer	Understand applicable technical and contractual requirements
ISSO	Manage authorization evidence, compliance obligations, and risk records
Security Control Assessor	Evaluate assessment objectives and defensible evidence

PRINT FORMAT

US Letter (8.5 x 11 in). Designed for a small reference binder: one focused topic per sheet.

Important: Framework applicability depends on the specific system, contract, data, authorization boundary, and governing authority. These sheets are educational summaries, not a substitute for current official requirements.

FedRAMP vs DoD RMF vs CMMC

These programs overlap in controls, but they answer different questions.

Framework	Primary purpose	Typical scope
FedRAMP	Standardized federal cloud security assessment and authorization approach	Cloud service offerings used by federal agencies
DoD RMF	DoD system cybersecurity risk management and authorization	DoD information systems and applicable IT
CMMC	Assess contractor implementation of required safeguards for covered information	Defense contractor environments handling FCI/CUI, as contractually applicable

Avoid the common mistake

A CMMC status does not itself constitute a DoD ATO. A FedRAMP authorization does not automatically grant DoD IL5 authorization. An ATO is a decision for a defined system and boundary, not a universal compliance badge.

THREE-ROLE LENS

Cybersecurity Engineer	ISSO	SCA
Map services and safeguards to system requirements.	Track which obligations and authorization artifacts apply.	Verify assessment scope, inheritance claims, and evidence.

KNOWLEDGE CHECK

1. Why is CMMC not interchangeable with an ATO? 2. What does an authorization boundary establish?

SOURCE NOTES: NIST SP 800-37 Rev. 2; FedRAMP official program guidance; 32 CFR Part 170 (CMMC).

FedRAMP and DoD Cloud

FedRAMP in context

FedRAMP provides a federal approach for assessing and authorizing cloud service offerings, including a reusable security package and ongoing monitoring expectations. Authorization status and reuse depend on the specific offering and agency requirements.

DoD cloud considerations

The DoD Cloud Computing Security Requirements Guide (CC SRG) adds DoD-specific requirements and impact-level considerations. DoD provisional authorization and mission/system authorization are separate concepts; applicability and approval paths vary.

Concept	Practical assessment question
Cloud service offering boundary	Which components, regions, interfaces, and services are included?
Inherited controls	Which provider controls are documented and actually inherited?
Customer responsibilities	Which controls must the mission owner configure and operate?
DoD impact level	Does the intended data/mission fit the authorized service and deployment?

THREE-ROLE LENS

Cybersecurity Engineer	ISSO	SCA
Implement tenant-specific security configuration.	Maintain provider artifacts and customer control evidence.	Test claimed inheritance and customer-side controls.

KNOWLEDGE CHECK

Can a cloud provider package replace evidence for customer-configured Kubernetes RBAC? Explain.

SOURCE NOTES: FedRAMP.gov; DoD Cloud Computing SRG; NIST SP 800-53 Rev. 5.

CMMC, CUI and NIST 800-171

Information types

FCI (Federal Contract Information) and CUI (Controlled Unclassified Information) are distinct. Contract clauses, marking rules, and system scope matter. CMMC levels and assessment requirements are defined by the CMMC program and applicable contract terms.

Topic	What to remember
CMMC Level 1	Foundational safeguarding requirements for applicable FCI scope.
CMMC Level 2	Requirements tied to NIST SP 800-171 Rev. 2 under the current CMMC program rule; assessment type depends on contract requirements.
CMMC Level 3	Additional enhanced requirements and government assessment for selected programs.
Boundary and evidence	Identify in-scope systems, assets, information flows, and external service dependencies.

Key distinction

NIST SP 800-171 is aimed at protecting CUI in nonfederal systems; NIST SP 800-53 provides a broader catalog of security and privacy controls used in federal system risk management. Do not treat control numbers or assessment results as automatically equivalent.

THREE-ROLE LENS

Cybersecurity Engineer	ISSO	SCA
Implement CUI safeguards and protect data flows.	Maintain scope, SSP, evidence, and remediation records.	Evaluate only against the applicable criteria and assessment scope.

KNOWLEDGE CHECK

What additional information is needed before claiming a platform is CMMC compliant?

SOURCE NOTES: 32 CFR Part 170; NIST SP 800-171 Rev. 2; DoD CMMC program resources.

ATO, IATT, DATO and Risk Acceptance

Term	Meaning / caution
ATO - Authorization to Operate	AO accepts risk for operation of the specified system under stated terms.
IATT - Interim Authorization to Test	Limited authorization to conduct specified testing under defined constraints; not an unrestricted operational ATO.
DATO - Denial of Authorization to Operate	AO determines the system is not authorized to operate under the requested conditions.
Risk acceptance	Decision belongs to designated risk/authorization authorities; an SCA provides findings and recommendations, not the final authorization.

Decision package - simplified

SSP and boundary description + assessment plan/results + SAR + POA&M; + risk analysis + other required authorization materials. Actual DoD package content and workflow depend on the organization and system.

SCA vs AO

An SCA assesses security controls and reports results. The AO considers mission context, residual risk, and authorization recommendations to decide whether operation is acceptable.

THREE-ROLE LENS

Cybersecurity Engineer	ISSO	SCA
Remediate or mitigate technical deficiencies.	Coordinate the package and track open risks.	Produce independent findings and evidence-backed conclusions.

KNOWLEDGE CHECK

Who signs the authorization decision? Can an SCA approve their own findings as an ATO?

SOURCE NOTES: NIST SP 800-37 Rev. 2; DoDI 8510.01; applicable DoD/component RMF guidance.

FIPS 199, FIPS 200 and NIST 800-60

Publication	Role
FIPS 199	Defines low/moderate/high potential impact for confidentiality, integrity, availability.
FIPS 200	Sets minimum security requirements for federal information and systems.
NIST SP 800-60	Guidance for mapping information types to security categories.
NIST SP 800-53B	Control baselines and tailoring guidance used with categorization and requirements.

High-water mark concept

For federal system categorization, the overall system security category is determined using the highest impact value among the information types for each objective. Example: C=Moderate, I=High, A=Low gives an overall High system category. DoD categorization and overlays may add requirements.

Assessment sequence

Identify information types → evaluate confidentiality/integrity/availability impact → categorize system → select and tailor controls → implement → assess.

THREE-ROLE LENS

Cybersecurity Engineer	ISSO	SCA
Design controls appropriate to impact.	Document rationale and categorization decisions.	Check categorization assumptions and control selection evidence.

KNOWLEDGE CHECK

If integrity is High but confidentiality is Moderate, what is the overall FIPS 199 impact level?

SOURCE NOTES: FIPS 199; FIPS 200; NIST SP 800-60 Vols. I-II; NIST SP 800-53B.

Authorization Boundaries & Inheritance

The boundary is an assessment decision

Identify hardware, software, interfaces, cloud services, managed services, users, data flows, and external connections. Document where responsibility changes and what is explicitly excluded.

Control allocation	Evidence to seek
System-specific	Local policy, configurations, records, test results.
Common / inherited	Provider identification, scope, status, applicability, customer obligations.
Hybrid	Clear split between common provider and local implementation.

Example: RKE2 on AWS

AWS may provide physical facility controls; the platform team still owns many Kubernetes workload, identity, and logging controls. Do not assume that a provider authorization covers an incorrectly configured tenant role.

THREE-ROLE LENS

Cybersecurity Engineer	ISSO	SCA
Define technical architecture and security ownership.	Maintain the boundary, inventory, and inheritance matrix.	Validate the boundary and trace each claim to appropriate evidence.

KNOWLEDGE CHECK

What evidence would you request before accepting an inherited audit-logging control?

SOURCE NOTES: NIST SP 800-37 Rev. 2; NIST SP 800-53 Rev. 5; FedRAMP shared-responsibility guidance.

Mock Authorization Review

SCENARIO

A contractor hosts an RKE2 multi-tenant platform on an AWS cloud offering. It handles DoD CUI, claims CMMC Level 2 status, and seeks approval for a DoD mission at IL5.

Assess the claims

Claim A: “We have CMMC Level 2, so our platform already has an ATO.”
Claim B: “AWS has cloud authorizations, so every Kubernetes control is inherited.”
Claim C: “A vulnerability scan with no critical findings proves the system is secure.”

Suggested SCA approach

1. Establish the specific authorization boundary, information types, intended deployment, and applicable DoD cloud requirements.
2. Review provider authorization scope, inherited controls, and customer responsibilities.
3. Obtain SSP, SAP, SAR, POA&M;, architecture, and control implementation evidence.
4. Examine/interview/test selected objectives, including AC-3, AC-6, AU-2, and CM-6.
5. Record defensible findings and report residual risk; do not make the AO decision.

Three questions to answer

Which claims are unsupported? What additional evidence is necessary? Who has authority to accept the remaining operational risk?

THREE-ROLE LENS

Cybersecurity Engineer	ISSO	SCA
Provide architecture and configurations.	Coordinate authorization artifacts and stakeholders.	Challenge unsupported claims with objective evidence.

SOURCE NOTES: NIST SP 800-53A Rev. 5; NIST SP 800-37 Rev. 2; DoD CC SRG; CMMC rule.

VOLUME 8

Career & Interview Preparation

Cybersecurity Engineer / ISSO → Security Control Assessor

PURPOSE
Turn platform engineering experience into credible RMF, ISSO, and SCA interview stories. Practice evidence-based assessment reasoning rather than memorized compliance slogans.

Inside this volume

- Career positioning and role differences
- Your 60-second professional introduction
- High-yield ISSO interview questions
- High-yield SCA interview questions
- Technical-to-GRC translation matrix
- Mock assessment: Kubernetes AC-6
- Interview simulation and 30-day action plan

Print format: US Letter • 8 pages • margins suitable for standard home printers

1 | Career Positioning

A practical path to independent security assessment

Your positioning statement

CORE MESSAGE
Experienced software, architecture, DevSecOps and platform engineer transitioning toward RMF security assessment. Strong at connecting NIST requirements to implementation evidence in AWS and Kubernetes environments.

Role comparison

Cybersecurity Engineer: Implements and verifies technical safeguards; may own hardening, logging, scanning and remediation.

ISSO: Coordinates authorization documentation, continuous monitoring, POA&Ms, evidence and stakeholder reporting.

SCA: Independently assesses controls against approved objectives, documents results and supports risk-informed authorization.

What to emphasize in interviews

- Technical depth is a differentiator, not a substitute for assessment rigor.
- Distinguish control implementation, assessment findings and risk acceptance.
- Describe how you handle incomplete or contradictory evidence.
- Never imply an SCA grants an ATO; the Authorizing Official decides.

Three-role lens

Engineer: Explain how the safeguard works.
ISSO: Explain how it is documented and monitored.
SCA: Explain how its effectiveness is independently assessed.

Knowledge check

Who decides whether residual risk is acceptable for authorization? What is the SCA responsible for instead?

References: NIST SP 800-37 Rev. 2; NIST SP 800-53A Rev. 5.

2 | Your Interview Introduction

Use your experience without sounding like you only want engineering work

60-SECOND INTRODUCTION
“My background spans software development, architecture, DevSecOps and platform engineering, including AWS and Kubernetes in security-sensitive environments. I have spent years implementing and troubleshooting controls. I am now deliberately moving toward RMF and security assessment, where I can apply that technical understanding to evidence evaluation, risk communication and defensible control determinations. I am open to ISSO or cybersecurity engineering roles as a bridge, with independent security control assessment as my long-term direction.”

STAR answer framework

- Situation: Name the system, constraint and relevant security requirement.
- Task: Clarify your ownership and desired outcome.
- Action: Explain evidence gathered, tradeoffs, decisions and collaboration.
- Result: State measurable impact; do not invent numbers.
- Reflection: What would an assessor ask about the evidence?

Three stories to prepare

- A least-privilege or tenant-isolation decision in Kubernetes.
- A vulnerability/STIG remediation involving compensating controls or risk.
- A difficult cross-team security decision with documented follow-up.

Avoid these pitfalls

- Claiming a certification, eMASS depth or formal assessor authority you do not have.
- Calling a scan report proof that every related control is effective.
- Confusing policy existence with operational effectiveness.

Knowledge check

Can you deliver the introduction aloud in 60-75 seconds without jargon overload?

3 | ISSO Interview Questions

Authorization package, evidence and continuous monitoring

Questions and answer anchors

Q: What belongs in an SSP?
Boundary, environment, control implementation descriptions, responsible parties and inheritance, consistent with program requirements.

Q: How do you manage POA&Ms?
Trace each weakness to evidence, owner, milestones, due dates, status, and verification of closure.

Q: What does continuous monitoring mean?
Defined ongoing assessment, reporting, vulnerability/configuration oversight and risk updates, not just periodic scans.

Q: What would you do with missing evidence?
Identify the assessment need, request authoritative evidence, document the gap, and escalate on the program schedule.

Q: What does eMASS do?
Supports DoD RMF package and workflow management; local procedures and access differ by organization.

Q: How do you handle a significant system change?
Evaluate security impact, update relevant artifacts and engage the authorization chain under applicable guidance.

INTERVIEW TIP
Frame ISSO work as evidence stewardship and risk visibility, not simply “keeping paperwork current.”

Three-role lens

Engineer: Supplies implementation details and remediation.
ISSO: Maintains traceable authorization evidence.
SCA: Evaluates whether that evidence satisfies assessment objectives.

Knowledge check

Explain the difference between a POA&M closure request and independent verification that the weakness was resolved.

References: NIST SP 800-37 Rev. 2; NIST SP 800-137; applicable DoD RMF procedures.

4 | SCA Interview Questions

Demonstrate independent, repeatable assessment judgment

Q: What are the three assessment methods?
Examine, interview and test; selection and depth depend on approved procedures and assessment plan.

Q: How do you determine a control is effective?
Evaluate the applicable assessment objectives using sufficient, relevant, trustworthy evidence; record results and limitations.

Q: What if documentation and observed behavior disagree?
Preserve both sources, validate scope and currency, investigate discrepancy, and document an evidence-based determination.

Q: What is in a Security Assessment Plan?
Scope, objectives, methods, procedures, resources, schedule and assessment approach.

Q: What is in a Security Assessment Report?
Assessment results, identified weaknesses, supporting evidence and relevant risk information.

Q: What does assessor independence mean?
Appropriate separation from control development/operation, as required by system risk and governing direction.

Q: Who accepts risk?
The designated Authorizing Official, not the SCA.

Q: How do you validate remediation?
Reassess the relevant objectives with fresh evidence; document residual gaps and limitations.

STRONG ANSWER PATTERN
“I would first identify the exact assessment objective and approved procedure, then select examine/interview/test evidence, evaluate its quality, document the determination and communicate any limitation or finding.”

Knowledge check

Why can a screenshot be insufficient evidence of ongoing enforcement?

References: NIST SP 800-53A Rev. 5; NIST SP 800-37 Rev. 2.

5 | Translate Engineering to GRC

Connect familiar technical work to controls and assessment evidence

Engineering experience	Potential control focus	SCA evidence questions
Kubernetes RBAC	AC-2 / AC-3 / AC-6	Who can bind privileged roles? Are permissions tested?
AWS IAM roles	AC-3 / AC-6	Are trust policies scoped? Is access reviewed?
Audit collection	AU-2 / AU-6 / AU-12	Are events generated, protected and reviewed?
GitOps change flow	CM-3 / CM-5	Who approves changes? Can bypasses occur?
STIG and scanning	CM-6 / RA-5 / SI-2	What baseline applies? Are findings resolved?
Namespace isolation	AC-4 / SC-7 (as applicable)	What boundaries are claimed and actually enforced?

Important nuance

Mappings are illustrative. An implementation can support multiple controls, but no technology alone establishes control satisfaction. Select the applicable control statements, enhancements and assessment objectives for the actual authorization boundary.

Three-role lens

Engineer: Produces configurations, logs and test outputs.
ISSO: Maintains traceability to the SSP and monitoring records.
SCA: Evaluates the claims using approved assessment procedures.

Knowledge check

For a tenant namespace, what evidence would you need beyond an RBAC YAML file?

6 | Mock SCA Exercise: AC-6

Least Privilege on an RKE2 multi-tenant platform

SCENARIO
The SSP states that tenant operators can administer only their own namespaces. A service account has a ClusterRoleBinding to cluster-admin. The team says it is required for an automation job. You are assessing the relevant AC-6 objectives under the approved plan.

Assess in sequence

• Scope: Confirm boundary, applicable AC-6 enhancements, identities and inherited responsibilities.

• Examine: Review SSP claim, role/rolebinding exports, service-account usage, change approvals and access reviews.

• Interview: Ask owner why cluster-wide privilege is needed and how access is approved and monitored.

• Test: With authorization, verify effective permissions and whether lower privilege meets the workload need.

• Determine: Record objective-level results, uncertainty, evidence IDs and finding details.

Illustrative finding language

POTENTIAL DEFICIENCY
“The automation service account is bound to cluster-admin, while the documented function is limited to one namespace. The team has not provided evidence that cluster-wide privilege is required or periodically reviewed. Further evaluation against the applicable AC-6 objectives is needed.”

Avoid premature conclusions

A broad permission alone does not automatically prove every AC-6 objective is unsatisfied. Validate the system-specific requirement, authorized exceptions, scope and relevant evidence.

Three-role lens

Engineer: Removes unnecessary rights or documents justified need.
ISSO: Tracks evidence, ownership and remediation as appropriate.
SCA: Assesses the relevant objectives and validates remediation.

Knowledge check

Which new evidence would change your determination?

7 | Interview Drill & 30-Day Plan

A repeatable way to practice and move toward SCA

Five-question mock panel

- Walk us through an RMF authorization lifecycle.
- How would you evaluate an AC-6 claim for a Kubernetes platform?
- Describe a time you found a security design weakness and resolved disagreement.
- What is the difference between an SSP, SAP and SAR?
- How would you handle an unresolved finding near an authorization deadline?

Self-score each answer (0-2 points)

0: inaccurate or unsupported. 1: broadly correct but lacks evidence, ownership or method. 2: correct, concise, and grounded in process plus example. Total: /10.

30-day practice plan

- Week 1: Review RMF roles, boundaries and artifacts; rehearse your introduction.
- Week 2: Study 800-53A assessment methods; write an AC-6 mini assessment plan.
- Week 3: Produce an evidence inventory and draft two sample findings for a lab system.
- Week 4: Run two mock interviews, refine STAR stories and identify real assessment shadowing opportunities.

Your next career conversation

ASK YOUR MANAGEMENT
“I am interested in growing toward independent security control assessment. Are there opportunities to shadow our SCA team, help prepare assessment evidence, or participate in readiness reviews while remaining within independence requirements?”

Study sources

NIST SP 800-37 Rev. 2 (RMF); NIST SP 800-53 Rev. 5 (controls); NIST SP 800-53A Rev. 5 (assessment); NIST SP 800-137 (continuous monitoring). Confirm current DoD and program-specific direction before operational use.

Volume 9 | Field Reference & Appendices

A compact working companion to Volumes 1–8 • 14 US Letter pages • Engineer / ISSO / SCA

How to use

Use these sheets during study, interview rehearsal, evidence collection, and tabletop assessments. They are practical aids, not substitutes for authoritative assessment procedures or agency-specific policy.

Appendix map

Pages	Appendix	What you get
2–4	A · Glossary	RMF, DoD, assessment and cloud vocabulary
5–6	B · Control families	All 20 NIST SP 800-53 families, example evidence
7	C · Roles / RACI	Lifecycle accountability and independence
8–9	D · SCA checklist	Before, during and after assessment
10–11	E · Evidence and findings	Evidence matrix, reusable worksheet and example
12–13	F · DoD authorization	Decision terms, eMASS, STIGs and POA&Ms
14	G · Official sources	Standards, portals, currency and use notes

Three-role lens

Engineer: implements and demonstrates technical controls. ISSO: coordinates authorization artifacts, evidence and remediation. SCA: independently evaluates objectives and documents defensible results. Assignment of duties varies by organization; the assessor should remain appropriately independent.

Desk-reference concept

For a separate laminated card, use the seven RMF steps on one side and the SCA workflow on the reverse. This volume provides the content in pages 7–9.

A | Glossary 1 of 3

RMF roles, lifecycle and authorization

Term	Practical meaning
AO · Authorizing Official	Senior official accepting authorization risk and making authorization decisions.
AODR	Authorizing Official Designated Representative; assists AO within delegated scope.
SCA	Security Control Assessor; evaluates controls and reports results with appropriate independence.
ISSO	Information System Security Officer; supports security posture, records and coordination.
ISSM	Information System Security Manager; manages security program activities for assigned systems.
System owner	Official responsible for system development, operation and security requirements.
Common control provider	Organization providing controls inherited by multiple systems.
RMF	Risk Management Framework; seven-step process for system risk decisions.
Prepare	Establish context, roles, resources and risk strategy.
Categorize	Determine system impact using applicable categorization requirements.
Select	Choose, tailor and allocate controls.
Implement	Deploy controls and document implementation.
Assess	Determine whether controls meet assessment objectives.
Authorize	Decide whether system risk is acceptable.
Monitor	Track posture, changes, weaknesses and risk over time.

A | Glossary 2 of 3

Artifacts, assessments and remediation

Term	Practical meaning
SSP	System Security Plan: boundary, environment and control implementation.
SAP	Security Assessment Plan: scope, methods, procedures, team and logistics.
SAR	Security Assessment Report: results, deficiencies and risk-relevant observations.
POA&M	Plan of Action and Milestones: tracked weakness, remediation owner and dates.
CRM	Continuous risk monitoring / continuous monitoring, as defined by program.
Assessment objective	Specific statement to determine under SP 800-53A procedures.
Examine	Inspect records, configuration, documents or other artifacts.
Interview	Ask knowledgeable people to clarify processes and implementation.
Test	Exercise mechanisms or procedures and observe behavior.
Determination	Assessor conclusion against an assessment objective.
Finding	Documented condition with supporting evidence and relevant criteria.
Compensating control	Alternative safeguard proposed for a requirement; acceptability is program-specific.
Control inheritance	Use of controls provided by an authorized common-control provider.
Hybrid control	Control responsibility shared between system and common provider.
Residual risk	Risk remaining after safeguards and mitigations.
Significant change	Change that may alter risk, boundary, controls or authorization status.

A | Glossary 3 of 3

DoD, cloud and Kubernetes vocabulary

Term	Practical meaning
eMASS	Enterprise Mission Assurance Support Service; DoD RMF workflow/artifact platform.
DISA	Defense Information Systems Agency.
STIG	Security Technical Implementation Guide; product-specific configuration guidance.
SRG	Security Requirements Guide; broader security requirements by technology.
CCI	Control Correlation Identifier; links security requirements and control relationships.
CAT I / II / III	DISA finding severity categories; consult current STIG definitions.
SCAP	Security Content Automation Protocol; standardized machine-readable assessment content.
CUI	Controlled Unclassified Information.
FedRAMP	Federal cloud security assessment and authorization program.
CMMC	Cybersecurity Maturity Model Certification; DoD contractor assessment program.
IL4 / IL5 / IL6	DoD cloud impact levels; consult current DoD Cloud Computing SRG.
RKE2	Rancher Kubernetes Engine 2 distribution.
RBAC	Role-Based Access Control, including Kubernetes roles and bindings.
IRSA / Pod Identity	AWS mechanisms for associating IAM permissions with Kubernetes workloads.
KMS	Key Management Service; key lifecycle and cryptographic operations.
GitOps	Declarative configuration reconciliation from version-controlled sources.
AOA / ATO	Authorization-related acronyms vary by program; ATO means Authorization to Operate.

B | NIST Control Families 1 of 2

The first ten families in SP 800-53 Rev. 5. Examples are not exhaustive.

ID	Family	Example controls	Illustrative evidence
AC	Access Control	AC-2 accounts; AC-6 least privilege	IAM/RBAC exports; account reviews
AT	Awareness and Training	AT-2 literacy training	Completion records; curriculum
AU	Audit and Accountability	AU-2 events; AU-12 audit generation	Audit configs; sample events
CA	Assessment, Authorization, Monitoring	CA-2 assessments; CA-7 monitoring	SAP/SAR; monitoring plan
CM	Configuration Management	CM-2 baseline; CM-6 settings	Baselines; drift and STIG results
CP	Contingency Planning	CP-2 plan; CP-9 backups	Recovery plans; restore test
IA	Identification and Authentication	IA-2 user authentication	Identity policies; MFA evidence
IR	Incident Response	IR-4 handling; IR-6 reporting	Runbooks; incident exercise
MA	Maintenance	MA-2 controlled maintenance	Maintenance logs; approvals
MP	Media Protection	MP-6 sanitization	Sanitization records; procedures

Assessment reminder

A control ID is not itself an assessment test. Use the selected baseline, control enhancements, organizational parameters and the applicable SP 800-53A assessment objectives to define the actual procedures.

B | NIST Control Families 2 of 2

The remaining ten families and their common evidence patterns.

ID	Family	Example controls	Illustrative evidence
PE	Physical and Environmental Protection	PE-3 physical access	Badge/access logs; facility plan
PL	Planning	PL-2 SSP	Approved SSP; update history
PM	Program Management	PM-9 risk management strategy	Policies; enterprise risk artifacts
PS	Personnel Security	PS-3 screening	Screening procedures; records
PT	PII Processing and Transparency	PT-2 authority to process PII	Privacy notices; data inventory
RA	Risk Assessment	RA-3 risk assessment; RA-5 scanning	Risk register; scan evidence
SA	System and Services Acquisition	SA-9 external services	Contracts; supplier security reviews
SC	System and Communications Protection	SC-7 boundary protection	Network diagrams; traffic policy
SI	System and Information Integrity	SI-2 flaw remediation	Patch records; vulnerability status
SR	Supply Chain Risk Management	SR-3 controls and processes	Supplier inventories; risk decisions

Quick cloud mapping

AC: IAM and Kubernetes RBAC. AU: CloudTrail, Kubernetes audit and central log pipelines. CM: IaC, Fleet/GitOps and configuration checks. SC: network segmentation, ingress policy and encryption. SI/RA: image scans, node patching and remediation tracking.

C | Roles and RACI

Illustrative assignment only; tailor to local charter and DoD policy.

R = performs work; A = accountable/decision owner; C = consulted; I = informed. RACI is a planning tool, not an official DoD role assignment.

Activity	Engineer	ISSO	SCA	AO
Implement controls	R	C	I	I
Maintain SSP / evidence	C	R	C	I
Develop assessment plan	C	C	R	I
Execute independent assessment	C	C	R	I
Write SAR	C	C	R	I
Track remediation / POA&M	R	R	C	I
Review risk and authorization package	C	R	C	A
Make authorization decision	I	C	C	A
Monitor security posture	R	R	C	I

Seven-step RMF pocket map

1 Prepare → 2 Categorize → 3 Select → 4 Implement → 5 Assess → 6 Authorize → 7 Monitor.

SCA independence checkpoint

The team implementing a control can demonstrate its operation, but should not substitute its own assertion for independent assessment. Record potential conflicts, agreed scope and who approved assessment methodology.

D | SCA Checklist 1 of 2

Before evidence collection: make the assessment defensible.

☐ Authority and scope — Confirm assignment, system boundary, authorization status, selected controls and applicable overlays.

☐ Assessment baseline — Obtain approved SSP, control allocations, inherited controls and organization-defined parameters.

☐ Assessment plan — Define objectives, examine/interview/test procedures, sampling, schedule and constraints.

☐ Independence — Document assessor roles and any conflicts of interest.

☐ Evidence requests — Ask for artifacts by objective, system component, owner, period and provenance.

☐ Cloud inheritance — Identify provider vs customer responsibilities; verify current authorization scope.

☐ Technical access — Arrange read-only access where possible; approve tests that may affect production.

☐ Evidence protection — Use approved storage and handling for CUI, credentials, logs and system details.

☐ Interviews — Schedule control owners, operations staff, identity administrators and system owner.

☐ Traceability — Establish mapping: control → objective → evidence → determination → finding.

Evidence request example

AC-6: Provide current Kubernetes ClusterRoleBindings and RoleBindings, approved privileged-access criteria, last access review, service account inventory, and a read-only demonstration of effective permissions for selected identities.

D | SCA Checklist 2 of 2

During assessment and after reporting.

☐ Verify provenance — Capture evidence date, source, version, collector and system/boundary.

☐ Examine — Check policy, configuration and records against each selected objective.

☐ Interview — Confirm who operates controls, frequency, exceptions and escalation paths.

☐ Test — Use approved safe tests; record commands, inputs, expected and observed results.

☐ Corroborate — Resolve discrepancies between screenshots, statements and live configuration.

☐ Determine — Mark each objective satisfied / other applicable determination under methodology.

☐ Write findings — Record criterion, condition, evidence, affected scope, impact and recommendation.

☐ Validate facts — Conduct factual accuracy review without surrendering assessor independence.

☐ Report — Issue SAR and evidence traceability; protect sensitive attachments.

☐ Remediate / retest — Track weaknesses and independently verify closure when required.

One-minute assessment workflow

Objective → evidence request → examine / interview / test → observed result → determination → finding → SAR → remediation validation.

What not to do

Do not declare a control effective solely because a policy exists, a dashboard shows green, or a tool produces a passing score. Establish whether the required security outcome is implemented and operating for the defined boundary.

E | Evidence Evaluation Matrix

Illustrative requests; refine using 800-53A objectives and local assessment procedures.

Control	Ask for	Methods	Challenge question
AC-2	Account inventory; joiner/mover/leaver tickets	E / I / T	Are disabled users actually blocked?
AC-3	IAM/RBAC policies; authorization tests	E / T	Can an unauthorized identity act?
AC-6	Privileged bindings; reviews; exceptions	E / I / T	Why is cluster-admin necessary?
AU-2	Event selection; logging policy	E / I	Are relevant events specified?
AU-12	Audit config; raw sample events	E / T	Does activity generate records?
CM-6	Baseline; STIG results; deviations	E / T	Is drift detected and addressed?
RA-5	Scan reports; coverage; tickets	E / I / T	Are all in-scope assets scanned?
SI-2	Patch schedule; exceptions; retests	E / I	Are flaws corrected on time?
SC-7	Network diagrams; segmentation rules	E / T	Is tenant traffic actually restricted?

Evidence quality test

Relevant: tied to objective. Current: reflects assessed period. Authentic: attributable to trusted source. Complete: includes affected components. Reproducible: another assessor can follow the method.

E = Examine; I = Interview; T = Test. Method selection is illustrative and does not replace published procedures.

E | Finding Worksheet

Reusable form with a completed Kubernetes AC-6 example.

Field	Fill in during assessment
Control / objective	_____
System / boundary	_____
Criterion	_____
Condition observed	_____
Evidence / date / source	_____
Assessment method	_____
Affected components	_____
Risk / potential impact	_____
Recommended action	_____
Owner / response / status	_____

Completed miniature example — AC-6

Criterion: Approved least-privilege requirements and selected AC-6 objectives. Condition: A workload service account has a cluster-admin ClusterRoleBinding without documented justification. Evidence: Dated RBAC export, service-account inventory, owner interview, and approved non-disruptive permission test. Impact: Compromise of the workload may permit unauthorized cluster-wide actions. Recommendation: Scope the service account to documented permissions and retest. Disposition: Record finding in SAR and track remediation through the approved workflow.

Assessor writing tip

Distinguish observed fact from inferred risk. Avoid claiming exploitability or operational impact beyond what evidence supports.

F | DoD Authorization Quick Reference 1 of 2

Authorization is a risk decision, not a synonym for a scan result.

Term	Working interpretation
ATO	Authorization to Operate: AO accepts risk under specified conditions and duration.
IATT	Interim Authorization to Test: limited authorization for testing in a defined context.
DATO	Denial of Authorization to Operate: AO does not authorize operation.
AO decision	Risk-based authorization outcome; refer to governing DoD issuance for exact types.
eMASS	Workflow and recordkeeping for RMF package, controls, findings and decisions.
SSP	Describes boundary, architecture, controls, inheritance and implementation.
SAP / SAR	Defines assessment approach / reports assessment results.
POA&M	Tracks unresolved weaknesses, planned fixes and milestones.

Risk decision briefing — five questions

1. What is the mission and system boundary? 2. What controls are inherited vs locally implemented? 3. What did the assessment determine? 4. What open weaknesses and risk remain? 5. Who has authority to accept that risk?

Important distinction

A FedRAMP authorization or a DoD cloud provisional authorization does not automatically authorize a specific DoD mission system. Verify authorization scope, agency requirements, and the applicable AO decision.

F | DoD Authorization Quick Reference 2 of 2

STIG findings, remediation and cloud responsibilities.

Topic	What to verify
STIG / SRG	Applicable version, system scope, tailoring, approved deviations and results.
CAT I / II / III	Finding category and local response rules; never equate category directly with AO risk decision.
CCI	Traceability from requirement to control where mapping applies.
Automated scan	Coverage, credential level, false positives, manual checks and exclusions.
POA&M record	Weakness, evidence, impact, owner, planned action, milestones and validation.
Closure	Fix applied, retest performed, evidence retained, approvals recorded.
Cloud IL	Authorized hosting impact level and mission data restrictions.
Shared responsibility	Provider controls, inherited scope, tenant controls and evidence gaps.

Mini scenario: RKE2 cluster

A STIG scanner flags insecure kubelet configuration. Engineer: verifies node settings, documents fix via GitOps/automation and retests. ISSO: updates evidence, status and POA&M. SCA: verifies the applicable assessment objective and validates closure without relying solely on a scanner status.

Authorization boundary prompt

List nodes, workloads, AWS services, identity provider, network links, CI/CD, external dependencies and common controls. Identify which are in scope, inherited, or connected services. Boundary disputes can invalidate otherwise good evidence.

G | Official Reference Library

Use official source documents; check current revisions, overlays and program requirements.

Source	Primary reference / use	Official site
NIST	SP 800-37 Rev. 2 — RMF lifecycle	csrc.nist.gov
NIST	SP 800-53 Rev. 5 — control catalog	csrc.nist.gov
NIST	SP 800-53A Rev. 5 — assessment procedures	csrc.nist.gov
NIST	SP 800-137 — continuous monitoring	csrc.nist.gov
NIST	FIPS 199 / 200; SP 800-60 — categorization	csrc.nist.gov
NIST	SP 800-171 — CUI safeguards	csrc.nist.gov
DoD	DoDI 8510.01 — DoD RMF	esd.whs.mil
DISA	STIGs, SRGs, security content	public.cyber.mil
DISA	DoD Cloud Computing SRG	public.cyber.mil
FedRAMP	Current baselines, templates, authorizations	fedramp.gov
DoD CMMC	Program rules and assessment resources	business.defense.gov

Reference use and version control

Treat official portals as the source of truth for publication status. A document's listed revision may change after this guide is printed. For CMMC, confirm the current rule and assessment guide; for DoD, confirm AO/Component-specific processes and authorized tool access.

Final review: think like an assessor

Can I identify the requirement? Define the assessed boundary? Request relevant evidence? Choose a defensible method? Make an objective determination? Write a finding that another assessor can reproduce? Those six questions turn a control checklist into an assessment practice.

01 | Security Controls to Platform Technologies

PERKFORGE • Volume 10 • DoD RMF & Security Assessment Field Guide • 14 printable reference sheets

Purpose: Link a security need to a technical capability, an accountable team, a plausible NIST SP 800-53 Rev. 5 control, and objective evidence. This is a translation guide, not a product certification or a substitute for SP 800-53A procedures.

The five-part reasoning chain

Step	Question	Example
1. Requirement	What must the system accomplish?	Limit privileged access (AC-6).
2. Capability	What mechanism enforces it?	Kubernetes RBAC and AWS IAM.
3. Ownership	Who configures and operates it?	Platform / identity engineering.
4. Evidence	What proves it operates?	Bindings, approvals, effective-permission test.
5. Assessment	Does evidence satisfy selected objectives?	SCA documents determination and gaps.

Capability map

Domain	Tools / services	Typical control families
Identity	Keycloak, Okta, IAM, Rancher	IA, AC
Audit & detection	Alloy, Loki, Grafana, CloudTrail, SIEM	AU, SI, CA, IR
Secrets	Vault, KMS, External Secrets	IA, SC, AC
Configuration	Fleet, GitLab, Helm, Ansible, Terraform	CM, SA
Exposure & recovery	Trivy, Nessus, NetworkPolicy, Velero	RA, SI, SC, CP

Assessment caution

A tool may support a control without satisfying it. Actual compliance depends on configuration, operations, scope, parameters, and the assessed security outcome.

02 | Identity & Authentication

Keycloak / Okta / OIDC / SAML / MFA • Core families: IA, AC, AU

Security need → implementation

Need	Technical mechanism	What to request
Identify users	Federated identity; unique accounts; directory sync	User lifecycle procedures, directory mappings
Authenticate	OIDC or SAML sign-in; MFA; session controls	MFA enforcement, sign-in flows, policy export
Service identity	Client credentials, workload identity, certificate auth	Client inventory, scopes, credential lifetime
Account lifecycle	Provision, disable, deprovision; group synchronization	Tickets, disable tests, stale-account reports
Audit identity events	Keycloak events, IdP logs, downstream application logs	Successful/failed sign-ins, retention, alert review

Example control relationships

IA-2: user identification and authentication. IA-5: authenticator management. AC-2: account management. AU-12: generation of audit records. Exact applicability depends on the selected baseline and implementation.

Three-role perspective

Engineer: Integrates applications with IdP, enforces client and token settings, maintains authentication flows.

ISSO: Documents identity architecture, reviews account and MFA evidence, tracks exceptions.

SCA: Tests representative login, account disablement and audit events; checks bypass paths and scope.

Knowledge check

1. Does MFA cover every applicable access path, including administrative paths? 2. What happens to an active session when a user is disabled?

03 | Authorization & Least Privilege

AWS IAM / Kubernetes RBAC / Rancher • Core families: AC, IA, AU

Layer	Enforcement point	Evidence
Cloud	AWS IAM roles, policies, SCPs where applicable	Policy JSON, access analysis, role trust policies
Cluster	Kubernetes Role/ClusterRole and bindings	kubectl exports, subject inventory, access tests
Management UI	Rancher global / cluster / project permissions	Rancher role templates, assignments, tested access
Application	Keycloak roles / groups and application authorization	Claim mapping, app permission matrix, negative tests

Assessment trap

Authentication establishes identity; authorization decides what that identity may do. A Keycloak group claim does not prove a downstream application correctly enforces the intended permission. Rancher UI permissions also do not replace examination of effective Kubernetes access.

Practical test design

Select a normal tenant user, a platform administrator and a workload service account. Record expected access; compare to effective access using approved read-only checks such as kubectl auth can-i and review IAM policy evaluation. Confirm both allowed and denied actions.

Three-role perspective

Engineer: Defines roles and service-account permissions as code; avoids broad wildcards.

ISSO: Maintains access approval and periodic review records.

SCA: Assesses effective permissions, privileged exceptions and revocation behavior.

Knowledge check

1. Can a namespace administrator access other tenants? 2. Which service accounts can modify cluster-scoped resources?

04 | Audit Collection & Retention

Grafana Alloy / Loki / CloudTrail / Kubernetes audit • Core families: AU, SI

Reference telemetry path

Source	Collector / transport	Destination and proof
Kubernetes API audit	Audit policy and pipeline; Alloy where configured	Loki/SIEM; test event with identity and outcome
Keycloak auth events	Event listener, export or log integration	Central logs; failed sign-in and admin event
AWS API events	CloudTrail and supported delivery path	Protected trail, retention, access controls
Node / workload logs	Alloy or compatible collector	Log labels, source coverage, loss monitoring

The controls are about outcomes

AU-2: events selected for logging. AU-6: review, analysis and reporting. AU-9: protection of audit information. AU-11: retention. AU-12: record generation. Alloy moves telemetry; Loki stores/query logs; neither by itself proves review, protection, retention or complete coverage.

Three-role perspective

Engineer: Enables source audit policies, collection and reliable forwarding.

ISSO: Defines required events, retention, review cadence and evidence owners.

SCA: Generates a permitted event, traces it end-to-end and verifies retention/access restrictions.

Knowledge check

1. Can a privileged user alter or delete the only copy of an audit log? 2. Are missing agents and dropped events detected?

05 | Security Monitoring & Detection

Grafana / Prometheus / Alertmanager / SIEM • Core families: SI, CA, IR, AU

Security outcome	Platform component	Validation evidence
Detect suspicious activity	SIEM detections, Loki queries, Falco rules	Detection logic, alert test, tuning history
Monitor platform health	Prometheus metrics, Grafana dashboards	Scrape coverage, targets, outage alerts
Route actionable alerts	Alertmanager, Grafana Alerting, incident system	Routing rules, on-call records, acknowledgement
Investigate and respond	Tickets, incident runbooks, log search	Investigation trail, incident exercise, response time
Continuously assess	Scheduled evidence collection and review	Monitoring strategy, cadence, results, follow-up

Operational monitoring is not automatically security monitoring

CPU dashboards are useful for availability but do not establish detection of account abuse, policy changes, or unauthorized access. Define threat scenarios, events, detections, escalation and evidence that alerts reach responders.

Three-role perspective

Engineer: Builds telemetry pipelines, detection rules and reliable alert routing.

ISSO: Coordinates monitoring strategy, reporting, response evidence and open gaps.

SCA: Replays approved test events, verifies alert path and reviews response records.

Knowledge check

1. Who owns an alert after it fires? 2. How would you detect a disabled audit collector?

06 | Secrets, Keys & Encryption

Vault / AWS KMS / Secrets Manager / External Secrets • Core families: IA, SC, AC

Security need	Common implementation	Assessment evidence
Protect secrets at rest	KMS-backed encryption, encrypted storage	Key settings, encryption configs, access restrictions
Deliver secrets to workloads	External Secrets Operator, CSI, workload identity	SecretStore policies, service account scope
Rotate credentials	Vault dynamic secrets, rotation automation	Rotation schedule, change records, failed rotation alert
Control key access	KMS grants, Vault policies, separation of duties	Key administrator/use policies, access reviews
Protect transit	TLS, mTLS, certificate management	TLS config, certificate inventory, renewal evidence

Important distinction

External Secrets Operator synchronizes or retrieves secrets; it is not itself the authoritative secret store. Kubernetes Secrets are not automatically protected against every privileged cluster user. Verify encryption-at-rest configuration, access control, and exposure in logs or CI pipelines.

Three-role perspective

Engineer: Configures workload identity, policies, encryption and rotation.

ISSO: Documents key custody, exception process and evidence cadence.

SCA: Tests least privilege and rotation outcomes; inspects encryption scope and key access.

Knowledge check

1. Who can read a secret through Kubernetes API or etcd backups? 2. Can an application retrieve secrets without a long-lived static credential?

07 | Network & Tenant Isolation

NetworkPolicy / Cilium / Calico / security groups / mesh • Core families: SC, AC

Boundary	Mechanism	Evidence / test
AWS perimeter	VPC, subnets, security groups, route tables	Diagrams, rule exports, approved connectivity tests
Kubernetes namespace	NetworkPolicy with enforcing CNI	Policies, CNI support, cross-namespace deny test
Workload identity	Service accounts, RBAC, admission policies	Effective permissions, admission test
East–west encryption	Mesh mTLS or application TLS	Peer policy, certificates, traffic verification
Tenant capacity	ResourceQuota, LimitRange, scheduling isolation	Quotas, eviction/DoS assumptions, capacity review

Key concept

Namespaces are administrative scopes, not complete security boundaries. NetworkPolicy only works when supported and enforced by the cluster networking implementation. Resource quotas help contain resource consumption but do not replace network or authorization isolation.

Three-role perspective

Engineer: Implements deny-by-default segmentation and tests allowed paths.

ISSO: Documents tenant boundary, exceptions and ownership.

SCA: Attempts approved cross-tenant access and verifies policy enforcement and logging.

Knowledge check

1. Can one tenant reach another tenant’s service by IP? 2. What control prevents a tenant from reading another namespace’s secrets?

08 | Vulnerability & Image Scanning

Trivy / Grype / ECR / Nessus / STIG tooling • Core families: RA, SI, CM

Need	Technology	Assessment evidence
Discover flaws	Host, container and dependency scanners	Coverage inventory, authenticated scan status
Prioritize	Severity, exploitability, exposure, mission impact	Risk decisions, triage criteria, exceptions
Remediate	Patch pipelines, image rebuild, node updates	Tickets, release evidence, deployment versions
Harden configuration	STIG checks, baseline comparison, policy-as-code	Check results, approved deviations, manual validation
Verify closure	Rescan, package/version proof, configuration test	Before/after evidence, SCA retest where required

Scanner results are inputs, not conclusions

False positives, unreachable assets, unauthenticated scans, unsupported packages and compensating measures require analysis. A “zero critical vulnerabilities” dashboard cannot prove complete coverage or effective flaw remediation.

Three-role perspective

Engineer: Automates scanning and fixes affected components.

ISSO: Tracks findings, exceptions, owners, deadlines and POA&Ms.

SCA: Validates scan coverage and samples closed findings for retest.

Knowledge check

1. Does the inventory include all nodes, images and registries? 2. How are accepted risks and false positives documented?

09 | GitOps & Configuration Compliance

GitLab / Fleet / Helm / Ansible / Terraform • Core families: CM, SA, AU

Objective	Platform capability	Proof
Approved baseline	Version-controlled manifests and IaC	Protected branch, approved release/tag, baseline record
Change control	Merge requests, approvals, pipelines	Ticket linkage, review trail, deployment logs
Configuration enforcement	Fleet reconciliation, Ansible, policy-as-code	Drift alert, reconciliation logs, enforcement tests
Asset awareness	Inventory and GitOps cluster targeting	Cluster/namespace inventories, ownership mapping
Rollback and recovery	Releases, prior manifests, rollback procedures	Rollback drill, audit trail, recovery evidence

Do not confuse desired state with observed state

A merged Helm values file proves intent; the live cluster and reconciliation status show implementation. Also inspect who can bypass GitOps through direct kubectl or cloud-console changes.

Three-role perspective

Engineer: Implements reviewed change workflows and drift monitoring.

ISSO: Maintains baseline, change approvals and exception documentation.

SCA: Traces a change from approval to running state; tests unauthorized drift detection.

Knowledge check

1. Can production be changed without an approved merge request? 2. What happens when Fleet cannot reconcile a bundle?

10 | Software Supply Chain

GitLab CI / SBOM / Cosign / registries / admission • Core families: SA, SR, SI, CM

Need	Implementation	Evidence
Provenance	Build attestations, signed images	Signature verification, trusted identity policy
Component visibility	Syft SBOM, dependency inventory	SBOM coverage, update process, retained artifacts
Security gates	SAST, dependency and container scans	Pipeline policy, failed build example, exception workflow
Trusted deployment	Admission verification, registry allowlists	Enforced policies, denial test, audit records
Supplier risk	Approved registries and dependency review	Supplier inventory, assessments, remediation decisions

Assessment caution

Generating an SBOM is not the same as maintaining an actionable inventory. Signing an image is not enough unless deployment verifies the signature and trusts the intended signer. Distinguish advisory checks from enforced gates.

Three-role perspective

Engineer: Builds provenance, scans, signature verification and policy enforcement.

ISSO: Documents supply-chain policy, exception approvals and monitoring.

SCA: Tests unsigned/untrusted artifact rejection and checks pipeline bypass paths.

Knowledge check

1. Can an unsigned image deploy directly through kubectl? 2. Which entity or identity is trusted to sign production images?

11 | Backup, Recovery & Availability

Velero / S3 / AWS Backup / snapshots • Core families: CP, SC, SI

Security need	Typical implementation	Evidence
Backup critical state	Velero, DB backup, snapshots, object storage	Backup scope, schedule, encryption, status
Recover service	Restore workflows, runbooks, infrastructure rebuild	Restore exercise, elapsed recovery time, validation
Protect copies	S3 versioning/immutability where applicable, IAM	Deletion protections, key access, offsite strategy
Resilience	Multi-AZ patterns, replicas, failover	Architecture, failure test, monitoring alerts
Recovery planning	RTO/RPO, contingency procedures	Approved targets, test reports, corrective actions

Kubernetes-specific warning

Restoring Kubernetes resource manifests does not necessarily restore external databases, persistent volumes, encryption keys, or external IdP state. Validate complete application recovery, including dependencies.

Three-role perspective

Engineer: Automates backups and tests full restoration.

ISSO: Tracks contingency plan, recovery objectives and exercise findings.

SCA: Reviews scope and observes or examines a representative restore test.

Knowledge check

1. Which data would not be recovered by Velero alone? 2. When was the last successful restoration verified?

12 | Control-to-Tool Cross-Reference

Fast lookup: controls identify outcomes; tools are implementation candidates.

Control	Need	Typical tooling	Proof to sample
AC-2	Account lifecycle	Keycloak, IAM, Rancher	Provision / disable ticket and test
AC-3	Enforce access	RBAC, IAM, app policy	Allowed and denied access tests
AC-6	Least privilege	RBAC, IAM, Vault	Privileged roles, justification, effective access
AU-2	Audit event selection	K8s audit, CloudTrail, Keycloak	Selected event policy
AU-6	Audit review	Loki, SIEM, Grafana	Review evidence and follow-up
AU-12	Audit generation	Audit sources, Alloy pipeline	Generated event at destination
CA-7	Continuous monitoring	Grafana, SIEM, ticketing	Strategy, metrics, periodic reviews
CM-2	Baseline configuration	GitLab, Helm, Fleet	Approved baseline and deployed state
CM-6	Security configuration	STIG, Ansible, policy-as-code	Configuration evidence, deviation
CP-9	Backups	Velero, S3, AWS Backup	Backup and restore test
IA-2	Authentication	Keycloak, IdP, MFA	Login and MFA enforcement
RA-5	Vulnerability monitoring	Trivy, Nessus, ECR	Coverage, findings, retest
SC-7	Boundary protection	Cilium, SGs, NetworkPolicy	Segmentation and deny tests
SI-2	Flaw remediation	Patching, CI/CD, scanners	Fix timing and validation
SI-4	System monitoring	Falco, SIEM, alerts	Detection rule and response record

Assessment caution

Mapping is intentionally non-exclusive and illustrative. Consult the actual control text, enhancements, organization-defined parameters and SP 800-53A assessment objectives.

13 | SCA Evidence Request Cheat Sheet

A reusable script for requesting evidence from platform and DevSecOps teams.

Ask for five attributes with every artifact

Scope: systems and components. Period: dates covered. Source: authoritative system of record. Owner: responsible team. Method: how the evidence was generated and validated.

Domain	Targeted request
Identity	Provide IdP MFA policy, privileged user inventory, two recent deprovision records, and redacted authentication events.
Kubernetes RBAC	Provide current cluster-scoped privileged bindings, selected tenant namespace roles, approvals, and a permitted effective-access test.
Audit	Provide Kubernetes audit policy, CloudTrail settings, Alloy pipeline config, Loki retention and one traceable test event.
Monitoring	Provide detection inventory, alert routing rules, a recent test alert, acknowledgement and follow-up ticket.
Secrets	Provide key/secret access policies, workload identity mappings, rotation proof and encryption settings.
Network	Provide tenant boundary diagram, NetworkPolicies, security groups, and documented cross-tenant deny test.
GitOps	Provide approved baseline, one MR approval, Fleet reconciliation history and drift/override controls.
Recovery	Provide backup scope, recent completion history and a full restore exercise with results.

How to challenge weak evidence

Screenshot only? Ask for timestamp and source. Policy only? Ask for observed enforcement. Green dashboard? Ask about coverage and failure modes. Inherited? Ask for provider scope and customer responsibilities. Closed ticket? Ask for retest.

14 | Practical SCA Assessment: RKE2 Platform

Fictional system: AWS-hosted RKE2, Rancher/Fleet, Keycloak, Alloy, Loki, Grafana and GitLab.

Scenario

Three namespaces host separate application teams. Keycloak federates users into Rancher. Fleet applies platform configurations. Alloy forwards Kubernetes audit and Keycloak events to Loki; Grafana provides dashboards and alerts. AWS IAM, KMS and CloudTrail support the environment. The team asserts that AC-6, AU-12 and CA-7 are satisfied.

Objective	Ask / examine	Approved test / potential finding
AC-6	Rancher roles, RBAC exports, service account permissions, access approvals	Test tenant cross-namespace access. Unjustified cluster-admin would be a candidate deficiency.
AU-12	K8s audit policy, Keycloak event config, Alloy routes, Loki log samples	Generate approved auth/API events and trace arrival. Missing privileged API events indicate a gap.
CA-7	Monitoring strategy, alert catalog, review schedule, incidents and tickets	Trigger a safe test alert; verify owner, acknowledgement and follow-up evidence.

Write a mini assessment finding

Criterion: Selected assessment objective and local policy. Condition: Precisely observed deficiency. Evidence: Source, date, configuration and test. Impact: Plausible security consequence. Action: Recommended correction and validation. Do not equate a missing screenshot with a failed control without further inquiry.

Five-minute oral exam

Explain how an engineer proves a control is configured, how an ISSO maintains evidence over time, and how an SCA independently determines whether the required outcome is achieved.

Official references

NIST SP 800-53 Rev. 5 and SP 800-53A Rev. 5: csrc.nist.gov. DoD RMF: DoDI 8510.01 at esd.whs.mil. DISA STIGs/SRGs: public.cyber.mil. Verify current publications and local overlays before use.

Kubernetes-to-NIST SP 800-53 Mapping Guide

PerkForge RMF Binder | RKE2 / Rancher / AWS | NIST SP 800-53 Rev. 5 | US Letter

Purpose and scope

A printable reference connecting Kubernetes platform mechanisms to security control outcomes, implementation statements and Security Control Assessor (SCA) evidence. It supports SSP drafting, assessment preparation and interviews. It is not an authoritative one-to-one compliance crosswalk or a claim of authorization.

The mapping method

Requirement → implementation → responsibility → evidence → assessment. Select controls from the approved baseline and organization-defined parameters. Map each selected objective to the actual platform boundary and evaluate it using the applicable NIST SP 800-53A procedures.

Platform boundary inventory

Component	Examples	Boundary question
Cluster infrastructure	RKE2 control plane, worker nodes, etcd	Who patches, hardens and monitors each node?
Identity	Keycloak / external IdP, Rancher, Kubernetes API	Which identity and session controls are inherited?
Workloads	Namespaces, services, ingress, secrets	Which controls belong to tenants vs platform?
Delivery	GitLab CI, Helm, Fleet, registries	Are build and deployment paths in scope?
AWS services	IAM, KMS, S3, CloudTrail, VPC	What is provider-inherited vs customer-owned?

Three-role view

Engineer: configures and demonstrates controls. ISSO: records implementation, tracks gaps and coordinates evidence. SCA: independently tests selected objectives and reports results.

Identity, Access & Tenant Isolation

NIST control	Kubernetes / platform implementation	SCA evidence and tests
AC-2 Account Management	IdP lifecycle; Kubernetes and Rancher user/group bindings; service-account governance	Accounts, provisioning tickets, disabled-user test, periodic reviews
AC-3 Access Enforcement	Kubernetes RBAC; Rancher project roles; IAM permissions; admission controls	Role/ClusterRole bindings; effective access tests for sampled identities
AC-6 Least Privilege	Namespace-scoped roles; constrained service accounts; least-privilege IAM	Cluster-admin inventory; privilege justification; can-i tests
IA-2 Identification & Authentication	OIDC via Keycloak or other IdP; MFA for relevant user access	IdP policies, auth flow, login/MFA tests, session settings
IA-5 Authenticator Management	Credential lifecycle, workload identities, secret rotation	Rotation settings, ownership, expiry and revocation records
SC-7 Boundary Protection	VPC security groups, ingress controls, Kubernetes NetworkPolicy / CNI enforcement	Network diagram, policy YAML, deny/allow connectivity tests
SC-28 Protection at Rest	etcd encryption where configured, AWS KMS and storage encryption	Encryption settings, key access policy, storage configuration

Assessment trap

A namespace is an organizational boundary, not a complete tenant security boundary. Evaluate RBAC, network segmentation, admission policies, workload security, resource controls and administrative access together. NetworkPolicy requires a CNI implementation that enforces it.

SSP narrative example — AC-6

“The platform uses Kubernetes RBAC to restrict tenant identities to approved namespace resources. Privileged ClusterRoleBindings are limited to designated administrators and reviewed periodically. Evidence includes current bindings, access reviews and sampled effective-permission tests.” Adapt only when factually true.

Audit, Monitoring & Configuration

NIST control	Example implementation	SCA evidence / verification
AU-2 Event Logging	Kubernetes audit policy; Keycloak events; CloudTrail	Documented event selection and configured sources
AU-6 Audit Review	Loki/SIEM queries; alert routing; review procedures	Review records, investigations, alerts and escalation evidence
AU-9 Protection of Audit Information	Restricted log access, immutable or protected storage	Access controls, storage policies, tamper resistance
AU-12 Audit Record Generation	API server audit logs; Alloy collection pipelines	Generate approved sample events and verify end-to-end arrival
CA-7 Continuous Monitoring	Prometheus/Grafana, alert rules, evidence cadence	Monitoring strategy, metrics, response records
CM-2 Baseline Configuration	RKE2 configuration, Helm values, GitOps repositories	Approved baseline, versioned manifests and inventory
CM-3 Configuration Change Control	GitLab merge approvals, Fleet reconciliation	MR approvals, pipeline logs, deployment history
CM-6 Configuration Settings	DISA STIG/SRG checks, hardened node settings	Scan results, manual check evidence, exceptions
RA-5 Vulnerability Monitoring	Trivy, node scanners, registry scanning	Coverage, authenticated scans, findings, remediation
SI-2 Flaw Remediation	Patch pipeline, node upgrades, image rebuilds	Tickets, change approvals, retests, timelines

Telemetry is not a control by itself

Grafana, Alloy, Loki and Prometheus can support logging and monitoring, but successful assessment requires verifying relevant events, coverage, retention, integrity, review, alert handling and response. Metrics alone are not equivalent to audit records.

Resilience, Supply Chain & Ownership

NIST control	Example implementation	Evidence to seek
CP-9 System Backup	etcd snapshots; Velero; AWS Backup / S3	Schedules, scope, encryption, retention, successful restore test
CP-10 System Recovery	Documented cluster rebuild and application recovery	Recovery runbook, exercise, actual recovery measurements
SA-10 Developer Configuration Management	Protected Git branches, reviewed manifests and release tags	Change approvals, version history, rollback records
SA-11 Developer Testing	CI tests, policy checks, image scanning	Pipeline results, coverage and remediation of failures
SR-3 Supply Chain Controls	Approved images, signed artifacts, supplier review	Registry policy, signatures, SBOM and supplier records
SC-8 Transmission Confidentiality	TLS at ingress, internal TLS as required	Certificates, cipher policy, verified transport tests
SI-7 Software / Information Integrity	Admission signature verification, artifact digests	Enforcement policy, rejection test, signed build records

Responsibility and inheritance worksheet

Layer	Typical owner	Assessment question
Cloud provider	AWS (scope-dependent)	Which services/controls are covered by provider authorization?
Platform team	RKE2 / Rancher operators	Which controls are configured, maintained and evidenced locally?
Tenant team	Application / namespace owners	Who owns workload access, logging and secrets?
Security / GRC	ISSO, control owners, assessors	Who maintains SSP, tracks gaps and independently assesses?

Important

“Inherited” must be supported by provider documentation and verified applicability to the system boundary. Shared controls need explicit responsibility allocation. DoD cloud impact levels and mission authorization decisions are separate from a generic Kubernetes control mapping.

Practical SCA Exercise & Reference

Scenario: RKE2 platform with Keycloak, Fleet and Grafana Alloy

A tenant service account has a cluster-admin binding. Alloy collects application logs, but Kubernetes audit logging is disabled. Fleet deploys approved manifests from GitLab, and node scans show several unresolved STIG findings.

Objective	Evidence to request	Assessment action
AC-6 least privilege	Binding YAML, workload owner approval, service-account inventory	Verify effective privileges and business justification
AU-12 audit generation	API server flags/policy, log collector config, sample events	Run an approved audit-event generation test
CM-3 change control	GitLab approvals, Fleet history, exception process	Trace a production change from request to deployment
CM-6 secure settings	Applicable STIG checklist, scans, exceptions	Validate scope, finding accuracy and remediation evidence

Example assessment finding

Condition: A workload service account has cluster-admin without documented operational justification. Criteria: Applicable AC-6 objective and approved least-privilege policy. Evidence: Dated ClusterRoleBinding export, workload owner interview and approved effective-permission test. Risk: A compromised workload could gain broad cluster control. Recommendation: Restrict permissions and independently retest. Track through the approved SAR/POA&M workflow.

Evidence request mini-template

Control/objective: ____ Boundary/component: ____ Owner: ____ Artifact/source: ____ Evidence date: ____ Method: Examine / Interview / Test Determination: ____

Authoritative sources

NIST SP 800-53 Rev. 5 and SP 800-53A Rev. 5 (csrc.nist.gov); NIST SP 800-37 Rev. 2; DISA STIGs/SRGs (public.cyber.mil); Kubernetes documentation (kubernetes.io/docs); RKE2 documentation (docs.rke2.io); DoD RMF policy (esd.whs.mil). Check current versions and organization-specific requirements before operational use.